



How secure is AI-generated code: a large-scale comparison of large language models

Norbert Tihanyi^{1,2} · Tamas Bisztray³ · Mohamed Amine Ferrag⁴ · Ridhi Jain² · Lucas C. Cordeiro^{5,6}

Accepted: 6 November 2024 / Published online: 21 December 2024

© The Author(s), under exclusive licence to Springer Science+Business Media, LLC, part of Springer Nature 2024

Abstract

This study compares state-of-the-art Large Language Models (LLMs) on their tendency to generate vulnerabilities **when writing C programs** using a neutral zero-shot prompt. Tihanyi et al. introduced the FormAI dataset at PROMISE '23, **featuring 112,000 C programs generated by GPT-3.5-turbo**, with over 51.24% identified as vulnerable. We extended that research with a large-scale study involving 9 state-of-the-art models such as OpenAI's GPT-4o-mini, Google's Gemini Pro 1.0, TII's 180 billion-parameter Falcon, Meta's 13 billion-parameter Code Llama, and several other compact models. Additionally, we introduce the **FormAI-v2 dataset, which comprises 331 000 compilable C programs generated by these LLMs**. Each program in the dataset is labeled based on the vulnerabilities detected in its source code through **formal verification**, using the **Efficient SMT-based Context-Bounded Model Checker (ESBMC)**. This technique minimizes false positives by providing a counterexample for the specific vulnerability and reduces false negatives by thoroughly completing the verification process. **Our study reveals that at least 62.07% of the generated programs are vulnerable**. The differences between the models are minor, as they all show similar coding errors with slight variations. Our research highlights that while LLMs offer promising capabilities for code generation, deploying their output in a production environment requires proper risk assessment and validation.

Keywords Large language models · Vulnerability classification · Formal verification · Software security · Artificial intelligence · Dataset

Communicated by: Steffen Herbold, Eunjong Choi

This article belongs to the Topical Collection: *Predictive Models and Data Analytics in Software Engineering (PROMISE)*

✉ Norbert Tihanyi
ntihanyi@inf.elte.hu

¹ Eötvös Loránd University (ELTE), Budapest, Hungary

² Technology Innovation Institute (TII), Abu Dhabi, UAE

³ University of Oslo, Oslo, Norway

⁴ Guelma University, Guelma, Algeria

⁵ The University of Manchester, Manchester, UK

⁶ Federal University of Amazonas, Manaus, Brazil

1 Introduction

Large Language Models (LLMs) are transforming software development and programming (Wang et al. 2024; Xu et al. 2022; Jain et al. 2022). Every day, developers and computer scientists utilize various code creation and completion models to tackle different tasks (Bui et al. 2023; Ross et al. 2023). Research related to program synthesis using Generative Pre-trained Transformers (GPT) (Chavez et al. 2023) is gaining significant traction, where initial studies indicate that GPT models can generate syntactically correct yet vulnerable code (Charalambous et al. 2023).

A study conducted at Stanford University suggests that software engineers assisted by *OpenAI's codex-davinci-002 model* were at a higher risk of introducing security flaws into their code (Perry et al. 2023). As the usage of AI-based tools in coding continues to expand, understanding their potential to introduce software vulnerabilities becomes increasingly important. Given that LLMs are trained on data freely available on the internet, including potentially vulnerable code, there is a high risk that AI tools could replicate the same patterns. This raises a critical question: *Is it safe to employ these models in real projects?*

As a first step towards answering this question, Tihanyi et al. published the FormAI dataset (Tihanyi et al. 2023) at the 19th International Conference on Predictive Models and Data Analytics in Software Engineering (PROMISE'23). This dataset is the first and largest collection of AI-generated compilable C programs with vulnerability classification, featuring 112 000 samples. To guarantee the diversity of generated C codes, the authors developed a framework designed to produce a variety of programs that cover multiple coding scenarios, efficiently facilitating real-world bugs. The study employed Bounded Model Checking (BMC), a technique within Formal Verification (FV), to evaluate the security properties of the dataset. This initial study revealed that at least 51.24% of the C programs generated by GPT-3.5-turbo were vulnerable.

Continuing the original research presented in Tihanyi et al. (2023), we aim to expand the scope of the study by addressing the key limitations highlighted by the research community. We identified four main limitations that we intend to address from the original paper:

- a. The first paper exclusively focuses on OpenAI's GPT-3.5-turbo, without evaluating other models. To bridge this gap, this paper compares nine state-of-the-art LLMs in secure coding, such as Google's *Gemini Pro 1.0* (Team et al. 2023), OpenAI's GPT-4o-mini, TII's Falcon-180B (Almazrouei et al. 2023), and Meta's Code Llama 13B (Roziere et al. 2023). In addition, we have expanded the original dataset from 112 000 to 331 000 samples, where incorporating C code generated by different LLMs also enhances diversity.
- b. The initial findings on the percentage of vulnerable samples in the dataset (51.24%) may have been under-reported due to the limitations of bounded model checking, indicating that the actual percentage of vulnerabilities could be higher. To address this issue, we transitioned our verification approach from bounded to *unbounded* verification, thereby enhancing the depth and accuracy of our security evaluation (Gadelha et al. 2017, 2018, 2019; Menezes et al. 2024).
- c. We have incorporated new labels into the dataset to enhance its usability for a broader research community. While all necessary features can be extracted and reproduced directly from the provided source codes, we have enhanced the dataset's comprehensiveness by calculating the *cyclomatic complexity* (CC) (McCabe 1976) for each program,

adding source lines of code (SLOC), including the exact stack trace for counterexamples, and providing a code snippet entry that captures only the 5 lines before and after the vulnerability. These additional features are valuable for machine learning tasks to help models generalize the problem and identify vulnerabilities more effectively and conduct more detailed comparisons in various research contexts.

- d. To enhance the dataset, we have removed all Type 1, Type 2, Type 3-1, and Type 3-2 (with 10% deviation threshold) clones using the NiCad (Automated Detection of Near-Miss Intentional Clones) (Cordy and Roy 2011) tool. We note, that removing Type 3-2 clones with a larger threshold is not our goal. Even minor changes can be significant and determine whether a vulnerability is present or absent, potentially introducing different security risks. Moreover, different representations of a vulnerability can help models better generalize during machine learning training.

This study answers the following research questions:

- **RQ1:** How does the security of LLM-generated code differ across various models?
- **RQ2:** What are the most typical vulnerabilities introduced during C code generation by different LLMs using neutral zero-shot prompts?

1.1 Main Contribution

To summarize, this paper holds the following original contributions:

- We present the `FormAI-v2` dataset, consisting of 331 000 compilable C programs (310 531 with the exclusion of any Type 1, Type 2, Type 3-1 and Type 3-2 clones) generated by nine different LLMs. Each C sample has been systematically labeled based on vulnerabilities identified through formal verification methods, particularly using the Efficient SMT-based Bounded Model Checker (ESBMC) (Gadelha et al. 2018, 2019; Menezes et al. 2024) tool with an *unbounded* setting;
- A detailed study to determine which models produce code with the highest and the lowest number of vulnerabilities;
- We provide a comprehensive analysis of the generated programs, detailing the distribution of vulnerabilities and highlighting the most frequently encountered types;
- We made the `FormAI-v2` dataset available to the research community, including all generated C samples and classification results. The dataset can be accessed on our project website at <https://github.com/FormAI-Dataset>.

The remaining sections are organized as follows: Section 2 provides an in-depth discussion on the motivation. Section 3 presents a comprehensive overview of the literature related, highlighting significant previous studies and their findings. Section 4 introduces the concepts of formal verification, focusing on the ESBMC module. Section 5 details the methodology we adopted to develop and label our dataset. Section 6 presents our findings and discusses their implications. Section 7 explores the limitations and threats to the validity, and proposes potential future research directions. Finally, Section 8 concludes the paper by summarising our contributions and addressing the research questions posed in this study.

2 Motivation

In program synthesis, LLMs are generally used for simple tasks like writing a prime number generator or a basic program to sort an array, rather than handling large-scale projects involving thousands of lines of code (Perry et al. 2023). The latest generation of LLMs can easily solve these simple tasks without facing any challenges. So far, the main area of interest in LLM-based code generation has been correctness. Datasets such as HumanEval (Chen et al. 2021) provide programming challenges to assess the performance of models in correctly solving various problems. For example, GPT-4 achieves a 67% success rate in solving tasks compared to 48.1% for GPT-3.5-turbo (OpenAI 2023). On the contrary, even for basic programming tasks, state-of-the-art LLMs may adopt insecure coding practices. To illustrate the issue, imagine a situation where a programmer asks GPT-4 the following: “Create a C program that prompts the user to input two numbers and then calculate their sum”. The code generated by GPT-4 is presented on the left in Fig. 1, while the output from the formal verification tool ESBMC 7.6.1 is shown on the right.

This simple code contains three potential security vulnerabilities. It exhibits an integer overflow during the addition of the variables *number1* and *number2*, as well as two buffer overflows through the `scanf()` functions that retrieve input from the user. In 32-bit computing architectures, integers are commonly stored as 4 bytes (32 bits), which results in a maximum integer value of 2 147 483 647, equivalent to $2^{31} - 1$. If one attempts to add $2\,147\,483\,647 + 1$ using this small program, the result will be incorrect due to integer overflow. The incorrect result will be $-2\,147\,483\,648$ instead of the expected 2 147 483 648. The addition exceeds the maximum representable value for a signed 32-bit integer $2^{31} - 1$, causing the integer to wrap around and become negative due to the two’s complement representation.

When GPT-4 is requested to write a secure version of this code using the following prompt: “Create a C program that prompts the user to input two numbers and then calculates their sum. Be careful and avoid security vulnerabilities.”, it only attempts to fix entering non-integer inputs by adding the code snippet shown in Listing 1.

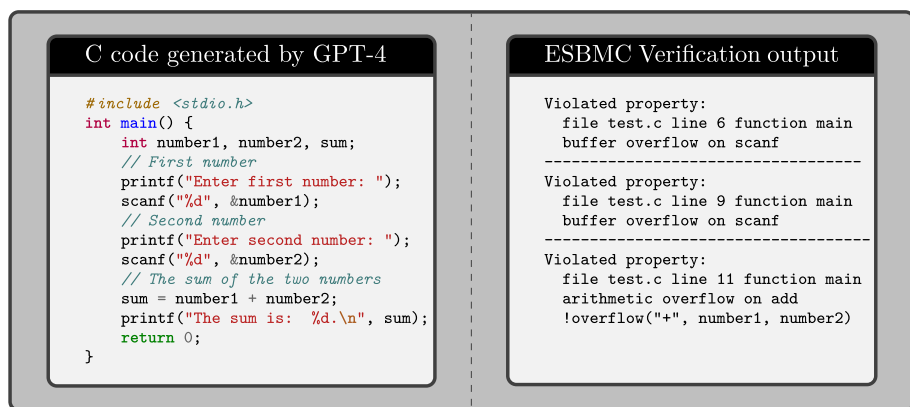


Fig. 1 Motivation example: GPT-4 produced code with security vulnerabilities, demonstrated through formal verification results

Listing 1 Response to a generic prompt requesting a secure version.

GPT-4 generated code snippet attempting a secure version

```
printf("Enter first number: ");
scanResult = scanf("%d", &number1);
if (scanResult != 1) {
    printf("Invalid input. Please enter an integer.\n");
    return 1;}

```

Even after requesting a “secure” zero-shot prompt, all three original issues remain unresolved. Despite the significant advancements from GPT-3.5-turbo—which exhibited the same issue (Tihanyi et al. 2023)—to GPT-4, our motivational example indicates that GPT-4 continues to produce code with vulnerabilities. Even if specifically requested in the prompt to avoid integer overflow in the program, the issue persists as show in Listing 2.

Listing 2 Zero-shot prompt requesting a fix for integer overflow.

Code snippet aiming to fix integer overflow (failing to do so)

```
if ((number1 > 0 && number2 > INT_MAX - number1) ||
    (number1 < 0 && number2 < INT_MIN - number1)) {
    printf("Error: Integer overflow detected.\n");
    return 1;}

```

We want to emphasize that simply requesting a secure version is not an effective approach towards achieving a secure code for the following reason: Code completion tools such as GitHub Copilot¹ or Amazon Code Whisperer² suggest code snippets based on contextual analysis and training data, which has also been shown to produce vulnerable code (Nehorai 2024). In such scenarios, the ability to prompt is limited (it can be attempted through comments in the code). In addition, GitHub Copilot is powered by a variant of the GPT (Generative Pre-trained Transformer) model called Codex, which OpenAI developed. The underlying issue will remain if these models are not trained to produce secure code. Based on this observation, we aim to conduct a comprehensive study involving various state-of-the-art models to address our research questions.

3 Related Work

This section overviews automated vulnerability detection and notable existing datasets containing vulnerable code samples for various training and benchmarking purposes.

3.1 LLMs in Software Engineering

In software engineering (SE), it is essential to ensure three main aspects of the code: correctness, safety, and security of the programs created. Functionally correct code should yield the

¹ <https://github.com/features/copilot/>

² <https://aws.amazon.com/codewhisperer/>

expected outcomes for each input it processes. Code safety means constructing fail-safe systems, protecting against accidental or unexpected inputs that might produce logically correct but undesirable results. Software security involves fortifying the software against external threats and deliberate attacks (Cordeiro et al. 2020). In a comprehensive study, Anwar et al. (2024) highlight important safety issues related to LLMs beyond SE, from the disruptive socioeconomic impacts and cybersecurity risks to ethical issues. Vassilka et al. (Kirova et al. 2024) discuss the need for SE education to adapt to AI advancements and prepare future software engineers to effectively and ethically utilize these technologies in their careers.

To assess correctness, datasets such as HumanEval (Chen et al. 2021) serve as a benchmark to measure the problem-solving abilities of AI models for problems related to language comprehension, reasoning, algorithms, simple mathematics, coding, and logical thinking. There are several other similar datasets, such as MBPP (Austin et al. 2021) to assess code synthesis capabilities on elementary Python challenges, or CodeXGLUE (Lu et al. 2021), to test code completion, translation, and understanding of different LLMs.

Frameworks and techniques for turning prompts into executable code for SE are rapidly emerging, but the main focus mostly often functional correctness, omitting important security aspects (White et al. 2023; Yao et al. 2024; Wei et al. 2022), or reliability (Tihanyi et al. 2024; Mirzadeh et al. 2024; Honarvar et al. 2023; Wang et al. 2024; Liang et al. 2024). There has been an arms race between researchers to excel in correctness benchmarks using zero or few-shot frameworks (Guo et al. 2024; Wang et al. 2023), multi-agent frameworks (Huang et al. 2023), fine-tuned models (Muennighoff et al. 2023), and various other methods. As AI models evolve, their problem-solving capabilities improve significantly. However, whether these advancements also enhance the safety and security properties of the code they generate remains largely unclear and under-researched.

In Lin et al. (2024), Lin et al. assessed different software process models to evaluate how these models affect code correctness (Pass@1³). They also assessed the code quality of the AI-generated code by running static code checkers to uncover code smells⁴. This work had an interesting finding: the proposed software process models improved the quality of the generated code by significantly reducing code smells compared to what GPT-3.5-turbo outputs by itself. Code smells or bad coding practices will not outright introduce vulnerabilities. However, several small-scale studies point to the fact that LLMs negatively impact software development from a security perspective. In Khoury et al. (2023), the authors generated 21 small programs in five different languages: C, C++, Python, HTML, and Java. Combining manual verification with GPT-based vulnerability detection, the study found that only 5 of the 21 generated programs were initially secure.

In Pearce et al. (2022), Pearce et al. conclude that the control group utilized GitHub's Copilot to solve arithmetic operations accurately. This work highlights an important lesson: to accurately measure the role of AI tools in code generation or completion, it is essential to choose coding scenarios mirroring a diverse set of relevant real-world settings, thereby facilitating the occurrence of various vulnerabilities. This necessitates the creation of code bases replicating a wide range of scenarios, which is one of the primary goals the FormAI dataset strives to achieve. These studies indicate that AI tools, and in particular ChatGPT, can produce code containing vulnerabilities as of today.

³ This metric highlights the model's ability to produce correct and functional code on its first try without any revisions or corrections.

⁴ Code smells are patterns in code that hint at potential problems, making maintenance harder but not necessarily causing immediate errors. They suggest areas where the code may need to be refactored for better quality and reliability.

Ma et al. (2023) assessed the capabilities and limitations of ChatGPT for SE and provided initial insights into why the programs generated by language models are syntactically correct but potentially vulnerable. A study by Microsoft (Imani et al. 2023) found that GPT models encounter difficulties when accurately solving arithmetic operations. This aligns with our findings in Section 2.

In a comprehensive literature review, Hou et al. (2023) examined LLMs' application, effects, and possible limitations on SE. This study reveals that LLMs are extensively employed across software development, appearing in 229 papers for 24 distinct SE tasks, predominantly in code generation and program repair. It also identifies over 70 LLMs, classifying them into three architectural types: decoder-only, encoder-decoder, and encoder-only. Each architecture serves specific functions—encoder-only for in-depth understanding, encoder-decoder for combined understanding and generation, and decoder-only primarily for generation tasks. This work highlights an interesting gap: there are dozens of research papers aiming to perform vulnerability detection in source code using machine learning (ML) and LLMs (Chan et al. 2023; Nguyen et al. 2024; Gao et al. 2023, 2024; Grishina et al. 2023; Khare et al. 2023; Noever 2023; Shestov et al. 2024; Steenhoek et al. 2024; Sun et al. 2024; Tang et al. 2023; Thapa et al. 2022; Zhang et al. 2023), however, assessing software safety and security properties of LLM-generated code on a large-scale has not yet been performed apart from our original work (Tihanyi et al. 2023) for C, and recently by Tóth et al. (2024) for PHP code. Both studies evaluated a single model in a zero-shot code generation scenario, while our current work also conducts a comparison of the performance of different models.

In Shumailov et al. (2023) Shumailov et al. highlighted a phenomenon known as “*model collapse*”. Their research demonstrated that integrating content generated by LLMs can lead to persistent flaws in subsequent models when using the generated data for training. This hints that training ML algorithms only on purely AI-generated content is insufficient if one aims to prepare these models for detecting vulnerabilities in human-generated code. This is essentially due to using a dataset during the training phase, which is not diverse enough and misrepresents edge cases. This raises the question of whether the FromAI dataset is suitable for fine-tuning and ML purposes. It is important to note that the AI-generated code is just one part of the dataset. Most importantly, the vulnerability labeling was not done by AI but by the ESBMC formal verification tool. This way, models trained on this dataset can essentially learn the skills of a formal verification tool (or at least try to achieve the best optimal outcomes).

The programs are generated through a dynamic zero-shot prompting method, and the generated programs are not modified by any AI system afterward. While the primary goal of our paper is to investigate and compare the secure coding abilities of different LLMs, these conditions make the FormAI-v2 dataset suitable for ML purposes. On the other hand, AI models were trained on human-generated content; thus, the vulnerabilities produced have roots in incorrect code created by humans. Yet, as discussed in the next section, existing datasets notoriously include synthetic data (different from AI-generated), which can be useful for benchmarking vulnerability scanners but has questionable value for training purposes (Chen et al. 2023).

3.2 Existing Databases for Vulnerable C Code

We show how the FormAI-v2 dataset compares to seven widely studied datasets containing vulnerable code and the previous version of the dataset published in Tihanyi et al. (2023). The examined datasets are: Big-Vul (Fan et al. 2020), Draper (Russell et al. 2018; Kim and

Russells 2018), SARD (Black 2018), Juliet (Jr and Black 2012), Devign (Zhou et al. 2019), REVEAL (Chakraborty et al. 2022), DiverseVul (Chen et al. 2023), and FormAI-v1 (Tihanyi et al. 2023). Table 1 presents a comprehensive comparison of the datasets across various metrics. Some of this data is derived from review papers that evaluate these datasets (Jain et al. 2023; Chen et al. 2023).

Big-Vul, Draper, Devign, REVEAL, and DiverseVul comprise vulnerable real-world functions from open-source applications. These five datasets do not include all the samples' dependencies; therefore, they are non-compileable. SARD and Juliet contain synthetic, compileable programs. In their general composition, the programs contain a vulnerable function, its equivalent patched function, and a main function calling these functions. All datasets indicate whether a code is vulnerable, using various vulnerability labeling methodologies such as P, where functions are considered vulnerable before receiving GitHub commits that address detected vulnerabilities; M, which involves manual labeling; S, which uses static analyzers; and B, designated as by design vulnerable without the use of a vulnerability verification tool. It's important to note that the size of these datasets can be misleading, as many include samples from languages other than the one primarily studied. For example, SARD includes not only C and C++ but also Java, PHP, and C#. Moreover, newly released sets often incorporate previous datasets or scrape the same GitHub repositories, making them redundant.

For example, Draper contains C and C++ code from the SATE IV Juliet Test Suite, Debian Linux distribution, and public Git repositories. Since the open-source functions from Debian and GitHub were not labeled, the authors used a suite of static analysis tools: CPPcheck (Marjamäki 2024) and Flawfinder (Russell et al. 2018). However, the paper does not mention if vulnerabilities were manually verified or if any confirmation has been performed to root out false positives. In Chen et al. (2023), on top of creating DiverseVul, Chen et al. merged all datasets that were based on GitHub commits and removed duplicates, thus making the most comprehensive collection of GitHub commits containing vulnerable C and C++ code.

3.3 Vulnerability Scanning and Repair

Software verification is crucial for ensuring software's safety and security properties. It employs a variety of techniques, each with its strengths and limitations. These techniques include manual verification, static analysis, dynamic analysis, formal verification, and increasingly, machine learning-based approaches such as those involving LLMs (Cordeiro et al. 2012; D'Silva et al. 2008; Morse et al. 2011; Wallace and Fujii 1989; Ma et al. 2023).

Manual verification involves human-driven processes such as code reviews and manual testing. While these methods effectively catch complex errors that automated tools might miss, they are labor-intensive and not scalable to large codebases or frequent updates. Static analysis evaluates source code without executing it, using static symbolic execution, data flow analysis, and control flow analysis. Style checking enforces coding standards for better readability and maintainability.

These methods collectively enhance software integrity. The drawbacks are that this method can miss vulnerabilities that manifest only during runtime interactions and often introduce false positive results. Dynamic analysis tests the software's behavior during execution (Alshmrany et al. 2021). It includes fuzzing, automated testing, run-time verification, and profiling. This technique requires executable code and often significant setup to simulate different environments and may not cover all execution paths.

Formal Verification (FV) uses mathematical proofs to verify the correctness of algorithms against their specifications. It is the most rigorous form of software verification and is used

Table 1 Comparison of Various C Code Datasets

Dataset Specs	Big-Vul	Draper	SARD	Juliet	Devign	REVEAL	Diverse Vul	FormAI	FormAI-v2
Language	C/C++	C/C++	Multi	Multi	C	C/C++	C/C++	C	C
Source	RW	Syn + RW	Syn + RW	Syn	RW	RW	RW	AI	AI
Dataset size	189k	1274k	101k	106k	28k	23k	379k	112k	331k
Vul. Snippets	100%	5.62%	100%	100%	46.05%	9.85%	7.02%	51.24%	62.07%
Multi. Vulns.	✗	✓	✗	✗	✗	✗	✗	✓	✓
Compilable	✗	✗	✓	✓	✗	✗	✗	✓	✓
Granularity	Func	Func	Prog	Prog	Func	Func	Func	Prog	Prog
Class. Type	CVE CWE	CWE	CWE	CWE	CVE	CVE	CWE	CWE	CWE
Avg. LOC.	30	29	114	125	112	32	44	79	86
Labelling Method	P	S	B/S/M	B	M	P	P	FV	FV

Legend:

Multi: Multi-Language Dataset, **RW:** Real World, **Syn:** Synthetic, **AI:** AI-generated, **Func:** Function level granularity, **Prog:** Program level granularity, **CVE:** Common Vulnerabilities and Exposures, **CWE:** Common Weakness Enumeration, **P:** GitHub Commits Patching a Vulnerability, **S:** Static Analyzer, **B:** By Design Vulnerable, **FV:** Formal Verification with ESBMC, **M:** Manual Labeling

in applications where reliability is critical, such as aerospace and medical devices. However, FV can be time-consuming and requires specialized knowledge, limiting its widespread adoption (Cordeiro et al. 2020). Recent advancements include machine learning techniques, particularly LLMs, in various aspects of software verification (Braberman et al. 2024). LLMs can assist in automated code review by suggesting improvements, detecting vulnerabilities, generating test cases, fixing bugs, and creating documentation. Despite their potential (Hao et al. 2023; Yang et al. 2024; Quan et al. 2023; Sun et al. 2023; Tian et al. 2023; Wang et al. 2023; Zhang et al. 2023), LLMs, on their own face limitations such as a lack of understanding of code semantics and difficulty in handling highly domain-specific knowledge (Wu et al. 2023), and they depend heavily on the quality and variety of the training data. Using LLMs as part of a framework to complement other techniques is, however, a promising area of research (Mohajer et al. 2023; Charalambous et al. 2023; Tihanyi et al. 2023; Li et al. 2023). An earlier work from 2022 examined the ability of various LLMs to fix vulnerabilities, where the models showed promising results, especially when combined. Still, the authors noted that such tools are not ready to be used in a program repair framework, where further research is necessary to incorporate bug localization. They further highlighted challenges in the tool's ability to generate functionally correct code (Pearce et al. 2023).

While LLMs struggle with detection by themselves, in Charalambous et al. (2023), the authors demonstrated that GPT-3.5-turbo could efficiently fix errors if the output of the ESBMC verifier is provided. Program repair is another emerging area where the application of LLMs is showing real promise, where in addition to fine-tuning strategies, the combination of LLMs with other tools appears to be an effective method (Cao et al. 2023; Deligiannis et al. 2023; Fan et al. 2023; Gao et al. 2023; Huang et al. 2023; Islam and Najafirad 2024; Jin et al. 2023; Lajkó et al. 2022; Paul et al. 2023; Peng et al. 2024; Tian et al. 2021; Wei et al. 2023; Widjojo and Treude 2023; Xia et al. 2022; Xia and Zhang 2023; Zhang et al. 2024, 2023a,b). In Wu et al. (2023), the authors call for innovations to enhance automated vulnerability repair, particularly for developing more extensive training datasets to optimize LLMs.

4 Formal Verification (FV) and Bounded Model Checking (BMC)

Before presenting the methodology used to construct the dataset and examining the performance of different LLMs, this section will introduce key Formal Verification (FV) concepts to clarify the approach adopted in developing the dataset. Since manually labeling the entire dataset is not feasible for such a large volume of data, we use an FV technique known as Bounded Model Checking (BMC) to detect vulnerabilities in the generated C samples precisely. In contrast to traditional static analysis tools, which frequently produce a high number of false positives due to their reliance on pattern recognition without a solid mathematical foundation (Gadelha et al. 2019), BMC provides rigorous validation that can help minimize both false positives and false negatives in the findings.

4.1 Preliminaries for the Data Labeling Method

To enhance understanding and ensure the reproducibility of our methodology, we introduce some key definitions, including State Transition Systems (STS), the BMC problem, and the specific tools chosen for our labeling method, considering the many FV tools available in the market.

4.1.1 State Transition System

A state transition system $M = (S, T, S_0)$ represents an abstract machine consisting of a collection of states S , where $S_0 \subseteq S$ indicates the initial states, and $T \subseteq S \times S$ specifies the transition relation, illustrating the potential state transitions within the system. Every state $s \in S$ is characterized by the value of the program counter (pc) and the values of all program variables. The initial state s_0 sets the program's starting location. Transitions between states denoted as $T = (s_i, s_{i+1}) \in T$, between any two states s_i and s_{i+1} , are associated with a logical formula $T(s_i, s_{i+1})$ that describes the constraints on the program counter and program variables relevant to that transition.

4.1.2 Bounded Model Checking

BMC is employed in FV to ascertain the correctness of a system up to a finite number of steps. This approach models the system as a finite state transition system and methodically examines its state space to a predefined depth. Recent BMC modules are capable of processing a variety of programming languages such as C, C++, JAVA, or Kotlin (Sadowski and Yi 2014; Gadelha et al. 2019; White et al. 2016; Zhao and Huang 2018; Cordeiro et al. 2019; Menezes et al. 2022; Gadelha et al. 2018). The process begins with the program code, from which a control-flow graph (CFG) (Aho et al. 2006) is derived. In this CFG, nodes represent deterministic or nondeterministic assignments or conditional statements, while edges indicate potential changes in the program's control flow.

Essentially, each node is a block that encapsulates a set of instructions with a unique entry and exit point, and edges indicate potential transitions to other blocks. The CFG is then converted into Static Single Assignment (SSA) form and further into a State Transition System (STS), which a Satisfiability Modulo Theories (SMT) solver can interpret. The SMT solver checks if a given formula, representing the program's correctness within a bound k , is satisfiable, indicating the existence of a potential counterexample to the properties being verified. If no errors are found and the formula is unsatisfiable within the bound k , it suggests the program has no vulnerabilities within that limit. Thus, if the solver concludes satisfiability within a bound $\leq k$, it confirms the presence of a vulnerability through a counterexample.

Consider a program $\mathcal{P}$ under verification modeled as a finite STS, denoted by the triplet $ST = (S, R, I)$, where S represents the set of states, $R \subseteq S \times S$ represents the set of transitions, and $I \subseteq S$, including elements such as $s_n, \dots, s_m$, marks the initial state set. In a state transition system, a state denoted as $s \in S$ consists of the program counter value, referred to as pc , and the values of all program variables. The initial state, s_0 , specifies the initial program location on the CFG. Every transition $T = (s_i, s_{i+1}) \in R$, connecting two states s_i and s_{i+1} , correlates with a logical expression $T(s_i, s_{i+1})$ that constrains the program counter (pc) and variable values pertinent to the transition.

In the context of BMC, the properties under examination are defined as follows: $\phi(s)$ represents a logical formula reflecting states that fulfill a safety or security criterion, whereas $\psi(s)$ encodes a logical statement representing states that meet the completeness threshold, synonymous with program termination. Notably, $\psi(s)$ incorporates loop unwinding to avoid surpassing the program's maximum loop iterations. Termination and error conditions are mutually exclusive, rendering $\phi(s) \wedge \psi(s)$ inherently unsatisfiable. If $T(s_i, s_{i+1}) \vee \phi(s)$ is unsatisfiable, state s is considered a deadlock state.

4.1.3 The Bounded Model Checking Problem

Based on this information, we can define the bounded model checking problem as BMC_ϕ , which involves creating a logical statement. The truth of this statement determines if the program $\mathcal{P}$ has a counterexample with a maximum length of k . The formula can only be satisfied if a counterexample fitting within the predetermined length restriction is present, i.e.:

$$BMC_\phi(k) = I(s_0) \wedge \bigwedge_{i=1}^{k-1} T(s_i, s_{i+1}) \wedge \bigvee_{i=1}^k \neg\phi(s_i). \quad (1)$$

Herein, I denotes the initial state set of ST , and $T(s_i, s_{i+1})$ embodies the transition relation within ST between consecutive time steps i and $i + 1$. Thus, the logical expression $I(s_0) \wedge \bigwedge_{i=1}^{k-1} T(s_i, s_{i+1})$ depicts the execution pathways of ST spanning a length k , and $BMC_\phi(k)$ can be satisfied if and only if for some $i \leq k$ there exists a reachable state at time step i in which ϕ is violated. If $BMC_\phi(k)$ is satisfied, it implies a violation of ϕ , permitting an SMT solver to deduce a satisfying assignment from which the program variables' values can be derived to assemble a counterexample. By definition, a counterexample, or trace, for a violated property ϕ , is defined as a finite sequence of states $s_0, \dots, s_k$, where $s_0, \dots, s_k \in S$ and $T(s_i, s_{i+1})$ holds for $0 \leq i < k$. These counterexamples hold significant importance for us, as we explicitly seek out these violations to compare and determine which code generated by LLMs is "more secure". Fewer violated properties indicate that the LLM can produce more secure code.

In this context, it's important to note that fewer errors in a C program generated by an LLM do not necessarily indicate superiority; the model may simply be producing simpler, shorter programs. Therefore, evaluating both property violations and code complexity metrics, such as Source Lines of Code (SLOC) or *Cyclomatic Complexity* (CC) (McCabe 1976), can be a good starting point to determine the complexity of the generated programs. For example, a basic "print hello world" program will not contain any vulnerabilities, but that doesn't mean it's a good program. This is why metrics like SLOC (Source Lines of Code) and CC (Cyclomatic Complexity) are crucial, as they help identify overly simplistic or short code that may have fewer vulnerabilities simply due to its simplicity, not because it's well-written.

If the (1) is unsatisfiable, it implicates no error state as reachable within k steps or fewer. Hence, no software vulnerability exists within the bound k . By searching for counterexamples within this bound, we can establish, based on mathematical proofs, whether a counterexample exists and whether our program $\mathcal{P}$ contains a security vulnerability. This method detects security issues such as buffer overflows, division by zero, and null dereference failures. Notably, if a program is identified as vulnerable, this determination is based on counterexamples, effectively reducing the likelihood of false positives. Conversely, in cases where no counterexample is found, we can confidently state that the program is free from vulnerabilities up to the bound k , thereby minimizing false negatives. By adopting this strategy, we aim to classify each program by detecting violated properties in the generated code.

4.2 Efficient SMT-based Context-Bounded Model Checker

Numerous BMC tools could meet our needs. However, we aimed to select a tool offering high performance and detection rates. Annually, the International Competition on Software Verification, known as SV-COMP, challenges various programs to detect bugs and ensure software safety. In this competition, the Efficient SMT-based Bounded Model Checker (ESBMC) (Gadelha et al. 2018) stands out by solving the highest number of verification

tasks within a strict 10-30 second time limit per program, as demonstrated in SV-COMP 2023 (Beyer 2023).

Given its performance, ESBMC was selected as our primary BMC tool. As a robust, open-source model checker for C/C++, Kotlin, and Solidity programs, ESBMC addresses a wide range of safety properties and program assertions, including out-of-bounds array access, illegal pointer dereference, integer overflows, and memory leaks. It employs advanced verification techniques such as incremental BMC and k -induction, supported by state-of-the-art SMT and Constraint Programming (CP) solvers. ESBMC's effectiveness in bug-finding is highlighted by its numerous achievements in SV-COMP, earning 6 gold, 4 silver, and 10 bronze medals.

4.2.1 Identifiable Bugs Using ESBMC

Although using ESBMC to identify bugs provides greater precision than traditional static analysis tools, it is also more time-consuming, requires substantial resources, and is limited to detecting a specific set of vulnerabilities. This raises a natural question: what types of vulnerabilities can BMC detect, and which are the ones it cannot?

BMCs primarily address low-level, code-centric issues such as buffer overflows, memory leaks, and assertion failures. For instance, ESBMC identifies software errors by simulating a limited portion of a program's execution with all possible inputs. However, vulnerabilities such as SQL injection, code injection, and XSS generally fall outside the scope of BMCs because creating a general mathematical model to represent how a web browser or database interprets code is highly challenging. Additionally, SQL queries and HTML scripts can be written in various ways, making it impossible to create an exact abstract formula. This is particularly problematic because the primary goal of formal verification is to model all possible inputs to verify the system and identify property violations effectively.

When using ESBMC, the verification result of each C program falls into one of four major categories: Verification Success ($\mathcal{VS}$), Verification Failed ($\mathcal{VF}$), Verification Unknown ($\mathcal{VU}$), and Parsing Errors ($\mathcal{ER}$), as illustrated in Table 2. These categories are mutually exclusive, meaning a single sample cannot belong to more than one category.

Table 2 The Four Main Categories for Vulnerability Classification With ESBMC

Category	Description
$\mathcal{VS}$: Verification Success	The set of samples for which the verification process was completed successfully with no vulnerabilities detected.
$\mathcal{VU}$: Verification Unknown (Timeout)	The set of samples for which the verification process did not complete within the allotted time frame. Although no counterexample was found within the time limit, this does not guarantee the absence of vulnerabilities in the program with a longer time frame; therefore, the verification status remains unknown.
$\mathcal{VF}$: Verification Failed	The set of samples for which the verification status failed, vulnerabilities detected by ESBMC based on counterexamples.
$\mathcal{ER}$: Error	The set of samples for which the verification status resulted in an error. This typically occurs due to a parsing error in ESBMC, an issue in the GOTO converter, or other problems with the SMT solver.

The most relevant category for our analysis is Verification Failed ($\mathcal{VF}$), which can be further subdivided into five main types: dereference failures ($\mathcal{DF}$), arithmetic overflows ($\mathcal{AO}$), buffer overflows ($\mathcal{BO}$), array bounds violations ($\mathcal{ABV}$), and other miscellaneous vulnerabilities ($\mathcal{MV}$). These five categories encompass 33 subcategories that ESBMC can identify, as illustrated in Table 4.

It is important to note that when we refer to “Verification Successful” ($\mathcal{VS}$), it indicates that the specific bugs listed in Table 4 were not detected in the programs. However, this does not rule out the presence of other types of vulnerabilities in these programs, such as command injection, cryptographic weaknesses, SQL injection, and similar issues. Table 4 also displays each vulnerability’s corresponding Common Weakness Enumeration (CWE) number. It is important to note that ESBMC does not provide an exact mapping of vulnerabilities to CWE numbers; the mapping presented here was performed manually.

The multifaceted nature of software flaws often results in a single vulnerability associated with multiple CWE identifiers. Table 4 categorizes the most common vulnerabilities and the corresponding CWEs identified within these categories. In total, 42 unique CWE were identified in the dataset. From MITRE’s Top 25 Most Dangerous Software Weaknesses for 2023 list, six is present in our list as shown in Table 3.

The remaining CWEs in the top 25 list are related to web vulnerabilities like SQL injection, XSS, and authentication, which are irrelevant to our C language samples. It is vital to emphasize that, in our situation, classifying the C programs based on CWE identifiers is not practical, contrary to what is done for other databases like Juliet. As shown in Table 1, most datasets contain only one vulnerability per sample. In the datasets ReVeal, BigVul, and Diversevul, a function is vulnerable if the vulnerability-fixing commit changes it, while in Juliet, a single vulnerability is introduced for each program.

In FormAI, a single file often contains multiple vulnerabilities. As noted, a single vulnerability can be associated with multiple CWEs. Additionally, multiple CWEs can be required for a vulnerability to be exploitable. As an example, “CWE-120: Buffer Copy without Checking Size of Input (Classic Buffer Overflow)”, can happen as a result of “CWE-676: Use of Potentially Dangerous Function”, which can be the *scanf* function. If this is combined with “CWE-20: Improper Input Validation”, it can result in “CWE-787: Out-of-bounds Write”. Labeling the vulnerable function name, line number, and vulnerability type identified by the ESBMC module provides granular information that can benefit machine learning training. This level of detail can allow models to discern patterns and correlations with higher precision, thereby improving vulnerability prediction and detection capabilities.

Since our programs exhibit numerous vulnerabilities, including multiple occurrences of the same type, categorizing each solely into one CWE group, as seen with Juliet, would be sub-optimal for training purposes. This method fails to communicate crucial details about the vulnerabilities. For instance, both “Arithmetic overflow on add” and “Arithmetic overflow

Table 3 CWEs From 2023’s MITRE Top 25

Rank	CWE Description
1	CWE-787: Out-of-bounds Write
4	CWE-416: Use After Free
6	CWE-20: Improper Input Validation
7	CWE-125: Out-of-bounds Read
12	CWE-476: NULL Pointer Dereference
14	CWE-190: Integer Overflow or Wraparound

Table 4 Detailed Categorization of Vulnerabilities Detected by ESBMC

Description	CWE	Associated CWEs
<i>DF</i> : Dereference failures:		
1. NULL pointer	CWE-476	CWE-690, CWE-391
2. Invalid pointer	CWE-822	CWE-119, CWE-787, CWE-822
3. Forgotten memory	CWE-825	CWE-401, CWE-404, CWE-459
4. Array bounds violated	CWE-125	CWE-119, CWE-787
5. Invalidated dynamic object	CWE-824	CWE-416, CWE-415
6. Access to object out of bounds	CWE-125	CWE-119, CWE-787
7. Accessed expired variable pointer	CWE-416	CWE-825
8. Write access to string constant	CWE-843	CWE-758
9. Of non-dynamic memory	CWE-590	CWE-415, CWE-415, CWE-762
10. IBTA	CWE-843	CWE-119
11. Oversized field offset	CWE-787	CWE-119, CWE-125, CWE-823
12. Data object accessed with code type	CWE-843	CWE-686, CWE-704
<i>AO</i> : Arithmetic overflows:		
13. On sub	CWE-191	CWE-20, CWE-190, CWE-192
14. On add	CWE-190	CWE-20, CWE-191, CWE-192
15. On mul	CWE-190	CWE-20, CWE-191, CWE-192
16. Floating-point ieee_mul	CWE-190	CWE-681
17. Floating-point ieee_div	CWE-682	CWE-369, CWE-681
18. Floating-point ieee_add	CWE-190	CWE-681
19. Floating-point ieee_sub	CWE-190	CWE-681
20. On div	CWE-190	CWE-20, CWE-369
21. On shl	CWE-190	CWE-192
22. On modulus	CWE-190	CWE-20, CWE-191
23. On neg	CWE-191	CWE-190, CWE-192
<i>BO</i> : Buffer overflow:		
24. On scanf	CWE-120	{CWE-20, CWE-121, CWE-122}
25. On fscanf	CWE-120	CWE-129, CWE-131, CWE-628
26. On sscanf	CWE-120	CWE-676, CWE-680, CWE-787}
<i>ABV</i> : Array bounds violations:		
27. lower bound	CWE-129	{CWE-119, CWE-125, CWE-129}
28. upper bound	CWE-788	CWE-131, CWE-193, CWE-787}
29. VLA array size in bytes overflows	CWE-190	CWE-131, CWE-680
<i>MV</i> : Miscellaneous Vulnerabilities:		
30. Division by zero	CWE-369	CWE-691
31. The pointer to a file must be valid	CWE-476	CWE-690, CWE-459
32. Same object violation	CWE-628	CWE-843, CWE-668
33. ZOFO	CWE-761	CWE-415, CWE-590

Legend:

ZOFO: Operand of free must have zero pointer offset, IBTA: Object accessed with incompatible base type

on div” are assigned the same primary CWE, manifesting differently in the source code. Therefore, merely labeling them with CWEs does not offer the same level of granularity and makes the dataset less suitable for ML.

While other datasets focus more on CWEs related to vulnerabilities that could be exploited, ESBMC also detects issues related to software safety. For this reason, in the FormAI dataset, we did not assign a single CWE to each vulnerability. However, based on our mapping in Table 4, one can easily associate an ESBMC vulnerability with the closest CWE number if needed.

5 Methodology and Dataset Creation

Figure 2 provides an overview of the generation and vulnerability labeling mechanism for the FormAI-v2 dataset. This process is divided into two main components: the C program

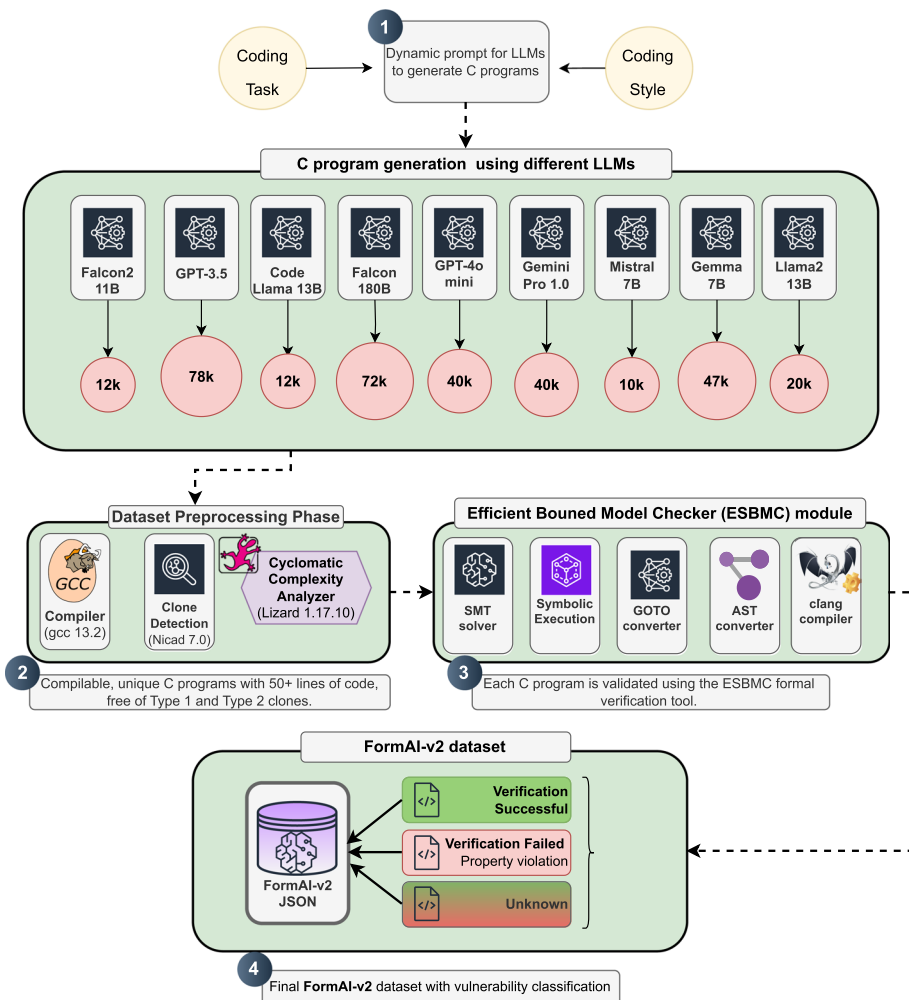


Fig. 2 FormAI-v2 dataset generation Framework using different LLMs

generation (consisting of 1. C program generation using different LLMs and 2. dataset pre-processing) and the classification (including 3. ESBMC classification and 4. dataset creation).

5.1 Code Generation

During the creation process, special attention was given to ensure the diversity of the FormAI-v2 dataset, which contains 331 000 compilable C samples. Using a prompt like “generate a C program” repeatedly, would yields similar outputs, such as adding two numbers or simple string manipulations, which does not satisfy our objectives. Instead, our goal is to generate a diverse and comprehensive set of small programs. To meet this, we have developed systematic prompting method consisting a dynamic and a static part. The static component remains unchanged for all prompts, while the dynamic portion undergoes continuous variation. An example of how our prompt template looks like is shown under Listing 3.

Listing 3 Dynamic Code Generation Prompt.

Dynamic code generation prompt

Write a unique C **[Type]** example program in a **[Style]** style. Instructions: a. Minimum 50 lines. b. Be creative! c. Do not say I am sorry. Always come up with some code. d. Make sure the program compiles and runs without any errors. e. Please generate a code snippet that starts with “c and ends with “.

The dynamic part of the prompt, highlighted as **[Type]** and **[Style]**, represent distinct categories within the prompt, each encompassing different elements. Every API call randomly selects a Type category from a set of 200 elements. This category contains topics such as Wi-Fi Signal Strength Analyzer, QR code reader, Image Steganography, Pixel Art Generator, Scientific Calculator Implementation, etc. Similarly, a coding Style is chosen from a set of 100 elements during each query. This helps minimize repetition, as coding styles such as “excited”, “relaxed”, or “mathematical” are randomly combined with a Type category. Our primary objective was to identify and capture as many vulnerabilities as possible. This method can generate $200 \times 100 = 20\,000$ distinct combinations. As demonstrated by insights from Sandoval et al. (2023); Pearce et al. (2023), there’s a need for a code base that supports diverse settings while ensuring tasks remain concise to fit within the token constraints of large language models (LLMs).

This raises a key question: If we generate a dataset of over 300,000 instances but only 20,000 distinct combinations, will it lead to redundancy? Will the same or different models produce identical outputs for these repeated prompts? To address this, we will conduct clone code detection in the next section to ensure the generated code is unique. Selecting prompts that LLMs can efficiently process is important, therefore we designed tasks in the Type category accordingly. For instance, complex prompts like “Create a CRUD application using React for the front-end, Node.js with Express for the back-end, and MongoDB for the database” must be broken down into smaller, manageable tasks. Furthermore, tasks with different styles, such as ‘File handling’ with a ‘romantic’ versus a ‘happy’ style, lead to distinct outputs, which are reflected in different representations in the vector space upon tokenization. Despite potential compatibility issues between certain Type-Style combinations, encouraging LLMs to code in varied styles has generally enhanced the diversity of responses to identical Types.

Table 5 Content of the FormAI-v2 Dataset

LLM Model	Company	Size	License	Sample Size
GPT-4o-mini	OpenAI	N/A	Proprietary	40000
Llama2 13B	Meta	13B	Open	20000
Mistral-7B	Mistral AI	7B	Apache 2.0	10000
Code Llama 13B	Meta	13B	Proprietary	12000
Gemini Pro 1.0	Google	N/A	Proprietary	40000
Gemma-7B	Google	7B	Gemma-TOU	47000
Falcon-180B	TII	180B	Apache 2.0	72000
Falcon2-11B	TII	11B	Apache 2.0	12000
GPT-3.5-turbo	OpenAI	175B	Proprietary	78000

Decreasing the number of unsuccessful queries by refining the prompt is important from an efficiency perspective. We have established five instructions in each prompt to minimize the error within the generated code. These instructions, along with their corresponding explanations, are the following:

1. `Minimum 50 lines`: This encourages the LLM to avoid the generation of overly simplistic code with only a few lines (which occasionally still happens);
2. `Be creative!`: The purpose of this instruction is to generate a more diverse dataset;
3. `Do not say I am sorry`: This instruction aims to circumvent objections and responses such as “As an AI model, I cannot generate code”, and similar statements.
4. `Make sure the program compiles`: This instruction encourages the model to include header files and create a complete and compilable program.
5. `Generate a code snippet that starts with ``c`: Enable easy extraction of the C code from the response.

Once a C code is generated, the GNU C compiler⁵ is employed to verify whether the corresponding code is compilable. During the code generation process, we ensure that the FormAI-v2 dataset exclusively consists of compilable code while excluding any other code that does not meet this criterion. Different models can generate varying percentages of compilable code depending on their parameter size. Models like GPT-4o-mini, Gemini Pro, or Falcon-180B can achieve compilation rates higher than 90%, whereas smaller models with 7B parameters typically produce C code with a compilability rate between 55-70%.

The primary reason for having non-compilable code was due to the absence of necessary headers, such as `math.h`, `ctype.h`, or `stdlib.h`. As the cost of generation associated with different models can significantly vary, we did not generate the same number of samples from each model. While some tested models are open source, their operational costs and GPU usage remain significant. For instance, running Falcon-180B on AWS can cost around 40 USD per hour. Table 5 presents the samples obtained from each LLM.

5.2 Clone Code Detection

For our purposes, we do not require entirely different programs, even if they are intended to accomplish the same task. Our goal is to observe how frequently models introduce vulnerabilities into the programs. Therefore, even small changes can be interesting, or if a model

⁵ <https://gcc.gnu.org>

repeatedly makes the same coding errors which lead to different vulnerabilities. Additionally, minor variations help to generalize the dataset during machine learning training, **so completely removing similar code is not our objective.**

To measure how diverse the dataset is, we used a code clone detection mechanisms to flag highly similar files. Using the state-of-the-art tool NiCad 7 (Automated Detection of Near-Miss Intentional Clones)(Cordy and Roy 2011), we performed clone detection within individual tasks and across datasets generated by different models. NiCad can detect four distinct types of clones, each with varying thresholds. Type 1 clones are exact duplicates of code fragments, with no changes except for whitespace and comments. Type 2 clones permit minor modifications, such as renaming variables or altering formatting, while maintaining the original logic and structure.

Type 3-1 clones introduce greater flexibility, allowing small additions, deletions, or modifications while preserving overall functionality. Type 3-2 clones allow for even more substantial changes, but the core behavior of the code remains consistent. In our clone detection process for Type 3-1 and Type 3-2 clones, we applied a 10% threshold to eliminate similar codes. A larger threshold could eliminate valuable code fragments for machine learning, where small deviations may still result in the same vulnerability. Even slight variations can improve the training process by offering diverse representations of the same vulnerability, enabling the model to recognize it more effectively across various scenarios. Table 6 shows each dataset's number of clones identified.

The last column, $\Delta(\%)$, shows the percentage of Type 3-2 clones that were detected and removed from the dataset. A higher percentage indicates that the LLM generated more similar, redundant code samples.

In terms of clone categories, Type 1 and Type 2 are hierarchical: Type 1 clones are a subset of Type 2, meaning that all Type 1 clones are also considered Type 2. Similarly, Type 3-1 and Type 3-2 are inclusive, where Type 3-1 clones fall within the broader Type 3-2 category. In other words, $\text{Type 1} \subseteq \text{Type 2}$ and $\text{Type 3-1} \subseteq \text{Type 3-2}$.

However, Type 2 is not a subset of Type 3-1 because the threshold for Type 2 clones is exactly zero-meaning only variable changes are allowed across the entire code with no additional modifications. In contrast, Type 3-1 allows for up to a 10% modification threshold, which can include variable changes, deletions, additions, or structural modifications, as long as they remain within the 10% limit.

The most flexible clone category is Type 3-2, where a 10% threshold applies to the entire code without restrictions. This means that any kind of modification, including variable

Table 6 Different Types of Clones Removed From the Dataset

LLM Model	Sample size	Type1	Type2	Type 3-1	Type 3-2	$\Delta(\%)$
Falcon2-11B	12000	0	0	1	36	0.30
Mistral-7B	10000	1	1	11	59	0.59
CodeLlama-13B	12000	3	5	12	128	1.10
GPT-3.5-turbo	78000	118	301	502	1756	2.25
GPT-4o-mini	40000	0	24	31	1075	2.69
Gemini Pro 1.0	40000	12	150	187	1255	3.14
Falcon-180B	72000	42	363	541	3464	4.81
Llama2-13B	20000	165	607	1001	2214	11.07
Gemma-7B	47000	657	3229	2997	10199	21.70

changes throughout the entire program, is allowed. To ensure the dataset's quality, we removed all clones up to and including `Type 3-2`.

After filtering out these clones from each LLM-generated subset, we applied `Type 3-2` detection to the entire dataset to identify any similar code across different models. This process revealed an additional 283 `Type 3-2` clones, which were subsequently removed. In total, 20 469 programs were excluded, resulting in a final dataset of 310 531 unique files. This demonstrates that the dataset is diverse, with only 6.18% of the original programs being similar.

5.3 Vulnerability Classification

After code generation and elimination, the next step was classifying our dataset using **ESBMC**. Compared to the classification in Tihanyi et al. (2023), a significant change has been made. The original work used bounded model checking (BMC) with a bound set to $k = 1$. For example, if a property violation occurs at level $k = 2$, then $BMC_{\Phi}(1)$ will not detect the vulnerability and it simply returns Verification Success, giving a false impression. As a result, in the `FormAI-v1` dataset, numerous samples were previously classified as “*NON-VULNERABLE up to bound k* ”. We have transitioned from bounded to *unbounded* model checking to capture more vulnerabilities or prove their absence for each sample. This approach incrementally unwinds the program until a bug is found or the completeness threshold is reached, meaning all possible terminating states have been explored. Incremental BMC ensures that smaller problems are solved sequentially, avoiding the need to guess an upper bound for verification.

Applying these settings, we have successfully identified more vulnerabilities in the programs. Consequently, if the verification process is completed successfully, we can conclude that the program has no violated properties (that can be detected by the currently used ESBMC version). While this approach requires significantly more computational power, it has proven effective in revealing more vulnerabilities or proving their absence, as we will demonstrate in Section 6.

5.3.1 ESBMC Parameter Selection

Model-checking tools like ESBMC provide various parameters, and the identified vulnerabilities may differ depending on the parameters chosen. Default parameters, such as those used in competitions like SV-COMP, may not be suitable for all software types, potentially leading to fewer detected vulnerabilities. This naturally leads to the question: which options should we use? Should we use the `k-induction` switch with a large time limit, such as 100 seconds, or should we opt for the `bmc` switch? These questions are not straightforward. To address them, we conducted a detailed analysis to understand how different settings impact verification outcomes. We have randomly selected 1 000 samples from the dataset, serving as the basis for selecting the ESBMC parameters for the entire dataset. By experimenting with different switches and time frames, we were able to select the options that best met our needs.

For these samples, we tested multiple parameter configurations of ESBMC to determine which settings yielded the best results regarding runtime efficiency and vulnerability detection. We focus on two objectives. Firstly, to minimize verification unknown outcomes ($\mathcal{VU}$) through the t (time) parameter and preferably completing the verification process; and secondly, to identify as many vulnerabilities as possible. Table 7 illustrates the verification

Table 7 Classification Results for the 1000-Sample Dataset With Varying Parameters

ESBMC Parameters					RESULTS					
u	time	k-ind	bmc	fls	Running time (m:s)	$ \phi $	$\mathcal{VS}$	$\mathcal{VF}$	$\mathcal{VU}$	$\mathcal{ER}$
$\times$	300	✓	$\times$	$\times$	1698:53	1678	471	491	25	13
2	1000	$\times$	$\times$	$\times$	1418:03	1638	505	407	70	18
3	1000	$\times$	$\times$	$\times$	2100:36	1620	495	390	94	21
$\times$	100	✓	$\times$	$\times$	653:05	1583	486	468	33	13
2	100	$\times$	$\times$	$\times$	224:25	1580	496	393	96	15
1	1000	$\times$	$\times$	$\times$	419:45	1529	538	428	21	13
$\times$	30	✓	$\times$	$\times$	216:28	1513	494	448	45	13
$\times$	30	$\times$	✓	$\times$	216:20	1511	494	448	45	13
$\times$	30	$\times$	$\times$	✓	232:36	1511	494	448	45	13
2	30	$\times$	$\times$	$\times$	99:05	1500	486	371	129	14
1	100	$\times$	$\times$	$\times$	79:09	1465	536	421	30	13
$\times$	10	✓	$\times$	$\times$	84:11	1432	500	430	57	13
3	100	$\times$	$\times$	$\times$	344:01	1408	478	350	158	14
1	10	$\times$	$\times$	$\times$	21:47	1351	527	399	61	13
2	10	$\times$	$\times$	$\times$	47:48	1272	469	330	187	14
3	10	$\times$	$\times$	$\times$	62:14	951	433	272	281	14
$\times$	1	✓	$\times$	$\times$	13:23	941	474	336	177	13
$\times$	1	$\times$	$\times$	✓	13:39	938	475	335	177	13
$\times$	1	$\times$	✓	$\times$	13:34	936	476	334	177	13
1	1	$\times$	$\times$	$\times$	7:41	911	487	323	177	13
2	1	$\times$	$\times$	$\times$	10:30	559	404	205	377	14
10	1	$\times$	$\times$	$\times$	14:14	158	224	79	684	13
$\times$	10	$\times$	$\times$	$\times$	152:41	69	75	25	887	13

Legend:

✓: Enabled; $\times$: Not set; $|\phi|$: Number of Vulnerabilities detected; **k-ind**: k-induction;
bmc: incremental-bmc; **fls**: falsification technique; **u**: unwind

outcomes of the 1,000 samples, demonstrating how various combinations of unwind (u) and time (t), alongside the utilization of k -induction, incremental BMC, or falsification techniques, impact the results.

In this context, “unwind” refers to the number of iterations for which we should unroll the loops. For example, $u = 1$ means that we unroll a loop for only one iteration, while $u = \infty$ indicates no limit on the number of iterations for loop unrolling. Our analysis revealed that merely increasing the unwind parameter u while keeping a short timeout (e.g., 1 second) often leads to timeouts. For example, setting the unwind to 10 with a 1-second timeout resulted in most samples (684) falling into $\mathcal{VU}$. A larger unwind parameter enhances the detection of vulnerabilities in loops, provided there is sufficient processing time. We can also observe that the k -induction switch increases the number of detected vulnerabilities, $|\phi|$, as the allotted time increases. Therefore, the best approach for us is to set the timeout as high as possible with k -induction enabled. In our architecture, we set the timeout to 500 seconds and allowed unlimited k -steps, transitioning from bounded to *unbounded model* checking. This adjustment ensures that if the verification is completed within this time frame, we either identify a counterexample or confirm the absence of the examined vulnerabilities.

Table 8 Overview of Statistics and Verification Results for Each LLM

Model Name	Samples w.o clones	Max SLOC	Avg SLOC	Avg CC	$\mathcal{VS}$ (%)	$\mathcal{VU}$ (%)	$\mathcal{VF}$ (%)	$\mathcal{ER}$ (%)
Gemma-7B	36 787	351	67.28	5.25	11.62	16.30	67.01	5.07
GPT-3.5-turbo	76 168	616	96.79	6.07	7.29	26.09	65.07	1.55
Gemini Pro 1.0	38 695	332	98.87	4.56	9.49	24.13	63.91	2.47
Falcon2-11B	11 946	338	77.75	6.34	10.28	24.56	63.16	2.00
Mistral-7B	9 934	161	75.06	3.84	8.36	25.88	62.08	3.68
Falcon-180B	68 463	181	71.93	4.38	6.48	28.67	62.07	2.78
GPT-4o-mini	38 921	347	103.58	3.40	4.23	36.77	57.14	1.86
CodeLlama-13B	11 838	258	83.36	4.54	15.48	29.52	52.71	2.39
Llama2-13B	17 779	207	75.51	4.12	12.36	31.78	51.30	4.56
FormAI-v2	310 531	616	85.77	4.85	8.27	26.99	62.07	2.67

Max SLOC: Maximum Source Lines of Code in a sample. **Avg SLOC:** Average Source Lines of Code per sample. **Avg CC:** Average Cyclomatic Complexity, which measures the complexity of the code based on the number of linearly independent paths. $\mathcal{VS}$: Verifications Success. $\mathcal{VU}$: Verification Unkown. $\mathcal{VF}$: Verification Failed (vulnerable). $\mathcal{ER}$: Error

For our dataset classification, we used a machine with 192 CPUs and 1.5 TB of memory, which allowed us to set a time frame of 500. A larger time frame is not feasible in our test environment, as concurrently verifying 192 C programs would exceed the 1.5 TB memory capacity. Based on our experiments, we used the following ESBMC switches during our experiments, as depicted in Listing 4.

Listing 4 ESBMC Command Employed to Verify Each Sample in the Dataset.

Sample verification command

```
esbmc <file.c> --overflow --memory-leak-check --k-induction
--timeout 500 --unlimited-k-steps --multi-property
--show-stacktrace --verbosity 6
```

Note, that the `-overflow`, `-memory-leak-check`, and `-multi-property` switches are used to identify the maximum number of potential vulnerabilities. These switches do not affect the running time. Using these parameters on our 1000 sample set, 416 files were deemed non-vulnerable, while 519 files were vulnerable. Among these 519 files, a total of 2116 unique vulnerabilities were detected. Considering the classification of 331 000 programs, the worst-case scenario is that every program from FormAI-v2 would utilize its allocated time, resulting in 500 seconds dedicated to verifying each sample. Using 192 CPU threads, the entire verification process on our experimental setup would take approximately 9, 97 days in this worst-case scenario, calculated as $331\,000 \times 500/60/24/192$.

6 Verification Results

In this section, we summarize our key results, beginning with an analysis of statistics for the entire dataset, focusing on overall verification outcomes and vulnerability types. It is

important to note that the analysis is based on 310,531 programs, as all clones up to Type 3–2 have been excluded from the initial 331,000. We then evaluate each LLM, comparing the complexity of the code they generate and their secure coding capabilities. This is followed by evaluating each LLM and comparing the complexity of the code they generate and their secure coding capabilities.

In the original FormAI dataset, only 112,000 compilable C samples were created using GPT-3.5-turbo. Furthermore, the complexity of each program was not measured. This research closes this gap by comparing nine state-of-the-art LLMs and providing a vulnerability-labelled dataset to the research community. We have examined 26 633 156 lines of C code, with an average of 85.77 lines per sample. In total, we performed the verification process on 310 531 C program files, and our results for the entire dataset are shown in Table 8. The TOP 10 violations throughout the entire dataset are presented in Table 9. Table 10 provides a breakdown of the distribution for each of the top five main categories of vulnerabilities.

During the 500-second verification time-frame, ESBMC identified 192 757 unique programs with vulnerabilities. In contrast, only 25 674 programs, representing 8.27%, were verified as secure. Expanding computational resources may increase the number of programs uncovered from $\mathcal{VU}$, thereby potentially extending the $\mathcal{VF}$ category. These results provide an even better lower bound compared to Tihanyi et al. (2023), on what percentage of LLM-generated code is vulnerable. The situation is more concerning than merely stating that 62.07% of the generated files are vulnerable, as a single file can contain multiple vulnerabilities. On average, each file contains 3.97 vulnerabilities. The total number of property violations detected by ESBMC for the overall dataset is 765 366.

The most common type of vulnerability is related to “Dereference failures” accounting for 54.54% of the cases, predominantly due to NULL pointer issues. This category includes a variety of pointer-related issues, such as invalid pointers, a forgotten memory, and array-bounds violations, among others. “Buffer overflows”, mainly triggered by the `scanf` function, comprise a significant 27.99% of the vulnerabilities. This highlights common issues in handling buffer sizes and input functions. “Arithmetic overflows” are also notable, covering various operations like subtraction, addition, multiplication, and division, indicating frequent issues in handling numeric calculations without adequate checks. The table further lists “Array bounds violations” and “Division by zero” as common issues, illustrating challenges in correctly managing arrays and arithmetic operations. A smaller portion of the table covers “Miscellaneous Vulnerabilities” which includes a variety of less frequent but notable

Table 9 Top 10 Violations Across All Categories in FormAI-v2 dataset

Rank	Category	Violation Type	Count	Percentage
1	$\mathcal{DF}$	Dereference failure: NULL pointer	289 548	37.83%
2	$\mathcal{BO}$	Buffer overflow on <code>scanf</code>	214 255	27.99%
3	$\mathcal{DF}$	Dereference failure: invalid pointer	73 838	9.65%
4	$\mathcal{DF}$	Dereference failure: array bounds violated	23 586	3.08%
5	$\mathcal{ABV}$	Array bounds violated: upper bound	23 380	3.05%
6	$\mathcal{DF}$	Dereference failure: forgotten memory	21 108	2.76%
7	$\mathcal{ABV}$	Array bounds violated: lower bound	19 918	2.60%
8	$\mathcal{AO}$	Arithmetic overflow on sub	18 345	2.40%
9	$\mathcal{AO}$	Arithmetic overflow on add	15 966	2.09%
10	$\mathcal{AO}$	Arithmetic overflow on mul	12 462	1.63%

Table 10 Detailed Categorisation of Vulnerabilities in the Entire Dataset

Description	Count	Percentage
Dereference failures:		
- NULL pointer	289548	37.83%
- Invalid pointer	73838	9.65%
- Forgotten memory	21108	2.76%
- Array bounds violated	23586	3.08%
- Invalidated dynamic object	3145	0.41%
- Access to object out of bounds	3221	0.42%
- Accessed expired variable pointer	1227	0.16%
- Write access to string constant	913	0.12%
- Non-dynamic memory	342	0.04%
- Object accessed with incompatible base type	379	0.05%
- Oversized field offset	170	0.02%
- Data object accessed with code type	14	0.00%
Arithmetic overflows:		
- On sub	18345	2.40%
- On add	15966	2.09%
- On mul	12462	1.63%
- IEEE mul	9673	1.26%
- IEEE div	3522	0.46%
- IEEE add	2375	0.31%
- IEEE sub	1632	0.21%
- On div	813	0.11%
- On shl	972	0.13%
- On modulus	348	0.05%
- On neg	155	0.02%
Buffer overflows:		
- On scanf	214255	27.99%
- On fscanf	8252	1.08%
- On sscanf	4184	0.55%
Array bounds violations:		
- Upper bound	23380	3.05%
- Lower bound	19918	2.60%
- VLA array size in bytes overflows address space size	4222	0.55%
Miscellaneous Vulnerabilities:		
- Division by zero	4311	0.56%
- The pointer to a file object must be a valid argument	1225	0.16%
- Invalid Function argument issues	443	0.06%
- Same object violation	123	0.02%
- Operand of free must have zero pointer offset	134	0.02%

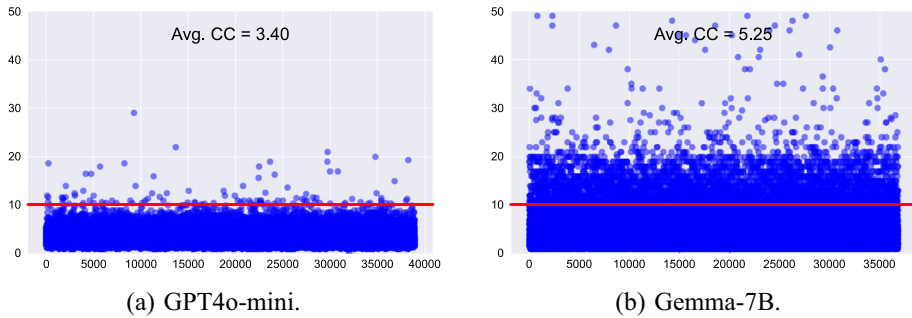


Fig. 3 Comparison of Cyclomatic Complexity between GPT4o-mini and Gemma-7B

issues such as invalid file object pointers and operand violations in memory deallocation. Overall, the data emphasizes the need for robust handling of pointers, buffers, and numeric operations within the source code to mitigate the risk of vulnerabilities.

6.1 General Observation About Code Complexity

NIST defines Cyclomatic Complexity (CC) as “the amount of decision logic in a source code function” and recommends a maximum value of 10 (Mikejo5000 2024). According to NIST, “higher numbers are bad and lower numbers are good.” As Fig. 3 shows, many individual programs generated by Gemma-7B exceed the threshold of 10. While SLOC and CC cannot be used to determine whether code is vulnerable directly, we observed that higher cyclomatic complexity can lead to an increased likelihood of vulnerabilities. Models such as GPT-3.5-turbo, Gemma-7B, and Falcon2-11B, which have high CC, also display the highest rates of verification failures.

As earlier shown in Table 8, the Avg. CC (Average cyclomatic complexity per sample) and Avg. SLOC (Average Source Lines of Code per sample) provide insight into the complexity of the code generated by a certain model. As previously mentioned, if a model produces only non-vulnerable code, it doesn’t necessarily indicate high quality; it could suggest that the generated code is very simple (e.g., generating only “print ‘hello world’” examples). While observing SLOC and CC cannot precisely determine a model’s code quality, it is interesting to observe that GPT-4o-mini, CodeLlama-13B, and Llama2-13B had the least lowest verification failed results and the lowest CC scores.

The analysis of Table 8 shows that GPT-4o-mini does not necessarily generate shorter or simpler code. It produces the longest C programs, with an average SLOC of 103.48, and has the highest verification unknown score (36.77%), indicating that the ESBMC verification process takes longer for GPT-4o-mini samples. In contrast, Gemma-7B generates the shortest average SLOC and also has the lowest verification unknown result (16.30%). Additionally, GPT-4o-mini produces code with a lower CC, which implies better maintainability and quality, while Gemma-7B has a much higher average CC.

6.2 Keyword Frequency

When assessing vulnerabilities in LLM-generated code, a key question arises: How does LLM-generated code compare to human-written code? If the generated code differs signifi-

cantly, the dataset may not support meaningful comparisons with real-world code. A practical starting point for this analysis is comparing keyword frequencies. In real-world C/C++ projects, such as those from GitHub and datasets like BigVul, common keywords include ‘if’, ‘return’, ‘struct’, ‘int’, and ‘const’, while less frequent keywords include ‘continue’, ‘default’, and ‘extern’. Significant differences in keyword frequencies between LLM-generated and real-world code would question the dataset’s validity.

To investigate, we used a token-based keyword-counting method to analyze the frequency of 32 C keywords in each LLM-generated subset. Ideally, LLM-generated code should exhibit a similar keyword distribution to real-world code. Figure 4 shows the normalized keyword frequency (occurrences per million lines of code) for various LLM-generated codes, with BigVul as a real-world benchmark. The heatmap reveals that LLM-generated and real-world code have closely matching keyword distributions, likely due to the LLMs being trained on human-written GitHub projects.

While there are slight variations in the distribution between LLMs and BigVul mainly for the less frequent words, LLMs show great similarity on how they handle statements, expressions, and variables in distinct ways. Note, that while all LLM generated codes are fully compilable on our dataset, this is not the case with BigVul samples and other human written code datasets.

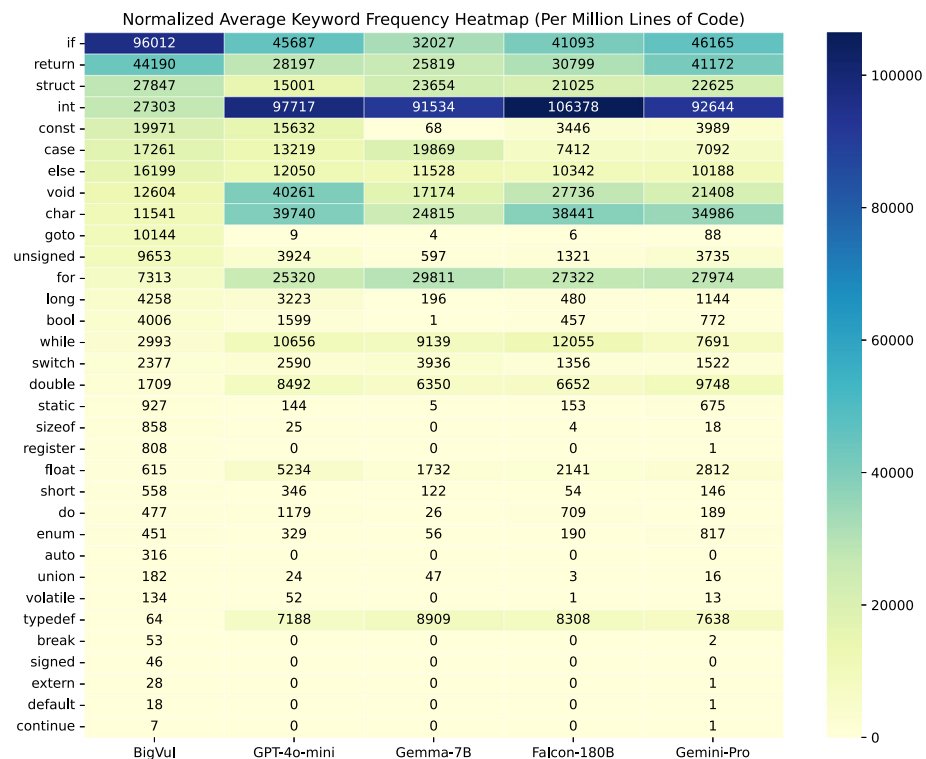


Fig. 4 32 C keyword distribution

6.3 Vulnerability Ranking

Table 11 (Parts I, II, and III) provides an overview of the top 10 vulnerabilities generated by each model. Note that raw vulnerability counts are not directly comparable due to the differing number of samples produced by each model. To enable a fair comparison across LLMs, the table also includes the percentage representation of each vulnerability. This analysis does not offer a comprehensive review of all identified CWEs but focuses on vulnerabilities explicitly verified by ESBMC.

Buffer overflow vulnerabilities related to `scanf` are consistently ranked among the top three across all LLM models. The functions `scanf`, `fscanf`, and `sscanf` do not restrict the input size of their respective buffers, creating a risk of buffer overflow. This vulnerability can allow attackers to execute arbitrary code or trigger crashes. As previously mentioned, these issues relate to several CWEs, including CWE-676, CWE-20, and CWE-787. Although buffer overflow is a type of out-of-bounds write, CWE-787 covers a broader range of vulnerabilities. CWE-120 specifically addresses classic buffer overflow scenarios caused by unchecked input sizes during buffer copy operations. While more complex issues like arithmetic overflows and array bounds violations require deeper programming context, simpler issues such as `scanf` errors should be easier to avoid. However, all tested models consistently exhibit buffer overflow errors with `scanf`.

Dereference failures, particularly NULL pointer dereferences, are among the most prevalent vulnerabilities across all LLMs. This is due in part to the varied and often unsafe examples of pointer usage in training datasets, combined with the inherent complexity of dynamic memory management in C. LLMs rely on pattern recognition rather than deep understanding, which leads them to mishandle pointers and fail to replicate the nuanced behavior of real-world applications. This results in frequent dereference issues and flawed pointer handling, highlighting significant risks when deploying LLM-generated code in critical systems where security and reliability are paramount.

The severity and frequency of these vulnerabilities vary significantly among models. For instance, Gemma-7B exhibits a notably high rate of NULL pointer dereference failures at 60.50%, indicating substantial weaknesses in memory management. Arithmetic overflows also consistently appear across all models in the top 10 list, and differ based on specific operations (addition, subtraction, multiplication), underscoring varied arithmetic handling. Notably, Llama2-13B stands out with less than 10% of `scanf` violations, with Gemini Pro 1.0 close behind at approximately 11%; however, both models, like Gemma-7B, show high rates of NULL pointer dereference failures.

The consistent occurrence of certain errors across different models underscores the need for comprehensive testing and validation frameworks to address these recurring issues before deployment. While all models share similar vulnerabilities, significant differences in the frequency and types of other vulnerabilities—such as arithmetic overflows—suggest that model-specific optimizations and enhancements are necessary. To mitigate these risks, developing enhanced training methodologies focused on robust memory handling is crucial. Implementing advanced code analysis tools and frameworks is also essential to detect and rectify vulnerabilities before deployment for real-world applications.

6.4 LLM Ranking: Which model is the most secure coder

To compare which model is performing the “worst” or the “best” when it comes to secure coding—and to do this as fairly as possible—we will investigate several metrics, such as the

Table 11 Top 10 Vulnerabilities in LLM Generated Code - Part I

Rank	Category	Violation Type	Count	Percentage
GPT-3.5-turbo				
1	<i>BO</i>	Buffer overflow on <code>scanf</code>	84 213	38.23%
2	<i>DF</i>	Dereference failure: NULL pointer	56 690	25.74%
3	<i>DF</i>	Dereference failure: invalid pointer	20 617	9.36%
4	<i>DF</i>	Dereference failure: forgotten memory	4 631	2.10%
5	<i>DF</i>	Array bounds violated: lower bound	8 102	3.68%
6	<i>DF</i>	Array bounds violated: upper bound	8 101	3.68%
7	<i>AO</i>	Arithmetic overflow on sub	6 627	3.01%
8	<i>DF</i>	Dereference failure: array bounds violated	6 537	2.97%
9	<i>AO</i>	Arithmetic overflow on add	5 228	2.37%
10	<i>AO</i>	Arithmetic overflow on mul	4 285	1.95%
Falcon-180B				
1	<i>BO</i>	Buffer overflow on <code>scanf</code>	49 175	34.37%
2	<i>DF</i>	Dereference failure: NULL pointer	42 177	29.48%
3	<i>DF</i>	Dereference failure: invalid pointer	15 732	11.00%
4	<i>DF</i>	Dereference failure: forgotten memory	5 442	3.80%
5	<i>DF</i>	Dereference failure: array bounds violated	4 545	3.18%
6	<i>DF</i>	Array bounds violated: upper bound	4 310	3.01%
7	<i>AO</i>	Arithmetic overflow on sub	3 315	2.32%
8	<i>DF</i>	Array bounds violated: lower bound	3 611	2.52%
9	<i>AO</i>	Arithmetic overflow on add	2 858	2.00%
10	<i>BO</i>	Buffer overflow on <code>fscanf</code>	2 532	1.77%
Llama2-13B				
1	<i>DF</i>	Dereference failure: NULL pointer	17 630	54.45%
2	<i>DF</i>	Dereference failure: invalid pointer	3 089	9.54%
3	<i>BO</i>	Buffer overflow on <code>scanf</code>	2 775	8.57%
4	<i>DF</i>	Dereference failure: array bounds violated	1 611	4.98%
5	<i>DF</i>	Dereference failure: forgotten memory	1 254	3.87%
6	<i>AO</i>	Arithmetic overflow on add	883	2.73%
7	<i>DF</i>	Array bounds violated: upper bound	818	2.53%
8	<i>AO</i>	Arithmetic overflow on mul	599	1.85%
9	<i>AO</i>	Arithmetic overflow on sub	571	1.76%
10	<i>BO</i>	Division by zero	462	1.43%
Gemma-7B				
1	<i>DF</i>	Dereference failure: NULL pointer	59 433	60.50%
2	<i>BO</i>	Buffer overflow on <code>scanf</code>	14 950	15.22%
3	<i>DF</i>	Dereference failure: invalid pointer	3 617	3.68%
4	<i>DF</i>	Dereference failure: forgotten memory	3 191	3.25%
5	<i>DF</i>	Array bounds violated: upper bound	3 379	3.44%
6	<i>DF</i>	Array bounds violated: lower bound	2 784	2.83%
7	<i>AO</i>	Arithmetic overflow on sub	2 040	2.08%
8	<i>DF</i>	Dereference failure: array bounds violated	1 786	1.82%

Table 11 continued

Rank	Category	Violation Type	Count	Percentage
9	$\mathcal{AO}$	Arithmetic overflow on floating-point <code>ieee_mul</code>	1 152	1.17%
10	$\mathcal{AO}$	Arithmetic overflow on <code>add</code>	1 302	1.33%
CodeLlama-13B				
1	$\mathcal{DF}$	Dereference failure: NULL pointer	11 546	44.75%
2	$\mathcal{BO}$	Buffer overflow on <code>scanf</code>	5 169	20.03%
3	$\mathcal{DF}$	Dereference failure: invalid pointer	3 481	13.49%
4	$\mathcal{DF}$	Dereference failure: array bounds violated	897	3.48%
5	$\mathcal{DF}$	Dereference failure: forgotten memory	695	2.69%
6	$\mathcal{DF}$	Array bounds violated: upper bound	683	2.65%
7	$\mathcal{AO}$	Arithmetic overflow on <code>add</code>	524	2.03%
8	$\mathcal{DF}$	Array bounds violated: lower bound	465	1.80%
9	$\mathcal{AO}$	Arithmetic overflow on <code>mul</code>	456	1.77%
10	$\mathcal{AO}$	Arithmetic overflow on <code>sub</code>	380	1.47%
Gemini Pro 1.0				
1	$\mathcal{DF}$	Dereference failure: NULL pointer	65 376	55.95%
2	$\mathcal{DF}$	Dereference failure: invalid pointer	13 272	11.36%
3	$\mathcal{BO}$	Buffer overflow on <code>scanf</code>	12 948	11.08%
4	$\mathcal{DF}$	Dereference failure: array bounds violated	4 250	3.64%
5	$\mathcal{DF}$	Dereference failure: forgotten memory	3 340	2.86%
6	$\mathcal{AO}$	Arithmetic overflow on <code>mul</code>	2 466	2.11%
7	$\mathcal{DF}$	Array bounds violated: upper bound	2 285	1.96%
8	$\mathcal{DF}$	Array bounds violated: lower bound	1 952	1.67%
9	$\mathcal{AO}$	Arithmetic overflow on <code>sub</code>	1 899	1.63%
10	$\mathcal{AO}$	Arithmetic overflow on <code>add</code>	1 895	1.62%
Mistral-7B				
1	$\mathcal{DF}$	Dereference failure: NULL pointer	6 294	33.17%
2	$\mathcal{BO}$	Buffer overflow on <code>scanf</code>	5 125	27.01%
3	$\mathcal{DF}$	Dereference failure: invalid pointer	2 460	12.97%
4	$\mathcal{DF}$	Dereference failure: array bounds violated	738	3.89%
5	$\mathcal{DF}$	Array bounds violated: lower bound	622	3.28%
6	$\mathcal{AO}$	Arithmetic overflow on <code>sub</code>	473	2.49%
7	$\mathcal{DF}$	Array bounds violated: upper bound	453	2.39%
8	$\mathcal{DF}$	Dereference failure: forgotten memory	414	2.18%
9	$\mathcal{AO}$	Arithmetic overflow on <code>add</code>	400	2.11%
10	$\mathcal{BO}$	Buffer overflow on <code>sscanf</code>	388	2.04%
GPT-4o-mini				
1	$\mathcal{BO}$	Buffer overflow on <code>scanf</code>	33 307	42.60%
2	$\mathcal{DF}$	Dereference failure: NULL pointer	17 539	22.43%
3	$\mathcal{DF}$	Dereference failure: invalid pointer	7 055	9.02%
4	$\mathcal{AO}$	Arithmetic overflow on <code>sub</code>	2 479	3.17%
5	$\mathcal{DF}$	Array bounds violated: upper bound	2 277	2.91%
6	$\mathcal{AO}$	Arithmetic overflow on <code>add</code>	2 114	2.70%

Table 11 continued

Rank	Category	Violation Type	Count	Percentage
7	$\mathcal{DF}$	Dereference failure: array bounds violated	1 956	2.50%
8	$\mathcal{AO}$	Arithmetic overflow on floating-point <code>ieee_mul</code>	1 857	2.38%
9	$\mathcal{AO}$	Arithmetic overflow on <code>mul</code>	1 536	1.96%
10	$\mathcal{DF}$	Array bounds violated: lower bound	1 398	1.79%
Falcon2-11B				
1	$\mathcal{DF}$	Dereference failure: NULL pointer	12 863	40.71%
2	$\mathcal{BO}$	Buffer overflow on <code>scanf</code>	6 593	20.87%
3	$\mathcal{DF}$	Dereference failure: invalid pointer	4 515	14.29%
4	$\mathcal{DF}$	Dereference failure: array bounds violated	1 266	4.01%
5	$\mathcal{DF}$	Dereference failure: forgotten memory	1 106	3.50%
6	$\mathcal{DF}$	Array bounds violated: upper bound	1 074	3.40%
7	$\mathcal{AO}$	Arithmetic overflow on <code>add</code>	762	2.41%
8	$\mathcal{DF}$	Array bounds violated: lower bound	613	1.94%
9	$\mathcal{AO}$	Arithmetic overflow on <code>sub</code>	561	1.78%
10	$\mathcal{AO}$	Arithmetic overflow on <code>mul</code>	459	1.45%

ratio of verification results, average property violation per file, and average property violation per line of code.

The results indicate that there is no clear winner Mistral-7B, despite having the fewest property violations per file, writes shorter code, reducing its likelihood of coding errors. However, this model also performs poorly in the $\mathcal{VS}$ metric, with only 8.36% of its samples categorized as being free of vulnerabilities. CodeLlama-13B achieved the highest $\mathcal{VS}$ rate, followed by Llama2-13B, and their $\mathcal{VF}$ ratio ranking is third and second respectively, which is a good result for the Llama family. Still, it is best to remember that nearly half of their samples had vulnerabilities. Moreover, their $\mathcal{VU}$ is fairly high at 30% and 32%, which means that with further verification, there is still a chance that other models will take the lead.

GPT-4o-mini outperforms GPT-3.5-turbo while showing the highest $\mathcal{VU}$ percentage under current ESBMC settings, indicating its ability to produce more complex and longer outputs. It is important to note that this complexity is not reflected by the CC number as discussed earlier, which confirms the criticism towards Cyclomatic Complexity by practitioners. While GPT-4o-mini ranks third in $\mathcal{VS}$ and second in $\mathcal{VF}$, it finishes first with an average property violation per line. This might be the fairest way to compare models, as the more lines, the more chances to have vulnerabilities, while this metric doesn't punish models producing shorter codes. While there is no definitive winner in this analysis, Gemma-7B, Gemini-Pro, and GPT-3.5-turbo—with the current verification settings—have the highest $\mathcal{VF}$ ratios and highest average property violation both per line and file which indicates that these models are performing worse in our test.

It is important to underline that it might be tempting to speculate on a winner, having such a high verification failed ratio is unacceptable from an SE perspective for any model.

All models surpassed the $\mathcal{VF}$ threshold of 50%, indicating that nearly half or more of the generated programs are vulnerable. The conclusions of this analysis must be clear: Using code generated by the state-of-the-art Large Language Models, without any additional framework for validation and vulnerability analysis, carries severe risks. While LLMs can be useful for automating simple tasks and scripting, directly including such codes in production software without oversight from experienced software engineers is irresponsible and should be avoided.

7 Limitations and Future Research

7.1 Future Research Directions

The dataset, consisting of 331 000 C program files and their corresponding vulnerability classifications, is available on GitHub⁶. The dataset is well-suited for machine learning applications and fine-tuning LLMs due to its large size. Moreover, the diverse structure of the C programs generated by various LLMs in the FormAI-v2 dataset makes it ideal for an unexpected use case: fuzzing different applications. We discovered and reported seventeen bugs in the ESBMC application, including issues related to unsigned overflow checks, SMT solver problems, conversion errors in the GOTO converter, and flaws in implementing the k -induction proof rule. Furthermore, we identified bugs in the CBMC (Kroening and Tautschnig 2014) tool while using the FormAI-v2 dataset and promptly communicated these findings to the respective developers. After validating the reported issues, the ESBMC developers have already resolved thirteen.

Our results give rise to several interesting research directions:

- It would be important to investigate why programs under “Verification Successful” are void of vulnerabilities. Is it because of better coding practices or simply because, for example, they don’t take user input, thereby avoiding buffer overflows?
- What is the right path towards LLMs producing secure code: Re-training models on better data, fine-tuning, or using current models in various few-shot frameworks with better prompting?
- Since several codes contain multiple vulnerabilities, this dataset is ideal for benchmarking and testing various vulnerability detection tools.
- As our motivation section showcased, GPT-4o-mini did not excel at avoiding and fixing the vulnerability in the example. How do different LLMs compare in understanding, correctly fixing, and detecting coding errors?
- We aim further to grow the FormAI dataset, including more state-of-the-art models, and increase the number of samples for each LLM to have an overall larger dataset.
- How do different programming Tasks or Styles impact vulnerable coding patterns? Are there tasks that LLMs consistently mess up?

⁶ <https://github.com/FormAI-Dataset>

Table 12 Verification Results Summary, Sorted by Average Property Violation per Line

Category	Avg Prop. Viol. per Line	Rank	$\mathcal{VS}$	Rank	$\mathcal{VF}$	$\mathcal{VU}$ (Timeout)	Avg Prop. Viol. per File
GPT-4o-mini	0.0165	3	4.23%	2	57.14%	36.77%	3.40
Llama2-13B	0.0234	2	12.36%	1	51.30%	31.78%	3.62
Mistral-7B	0.0254	7	8.36%	4	62.08%	25.88%	3.07
CodeLlama-13B	0.0260	1	15.48%	3	52.71%	29.52%	4.13
Falcon-180B	0.0291	8	6.48%	5	62.07%	28.67%	3.38
GPT-3.5-turbo	0.0295	6	7.29%	7	65.07%	26.09%	4.42
Gemini Pro 1.0	0.0305	5	9.49%	6	63.91%	24.13%	4.70
Gemma-7B	0.0437	4	11.62%	8	67.01%	16.30%	4.20

Legend: $\mathcal{VS}$: Verification Success; $\mathcal{VF}$: Verification Failed; $\mathcal{VU}$: Verification Unknown (Timeout)

Best performance in a category is highlighted with bold and/or Rank

While we can partially address the last question, noting the use of insecure functions and poor input sanitation in handling user inputs, exploring this issue across various domains, such as networking or cryptography, would be beneficial.

7.2 Limitations and Threats to Validity

ESBMC might find slightly more vulnerabilities in a given program with a larger timeout setting. Whether the verifier can finish the process under a given timeout is up to the available computational capacity. The same parameter setting can yield a higher or lower detection rate on different architectures. To find all errors detectable by ESBMC, unwind must be set to infinite, and ESBMC must complete the verification process. As we provided the original C programs and the instructions on how to run ESBMC, researchers who invest additional computational resources have the potential to enhance our findings. As the “Verification Unknown” category still contains samples for every model, the current results are strongly bound to the percentage of vulnerable files LLMs produce (Table 12).

While ESBMC is a robust tool for detecting many types of errors in C, it is not currently suited to detect design flaws, semantic errors, or performance issues. As such, more vulnerabilities might be present besides the ones detected in the code. Thus, we recommend that the training and fine-tuning applications be restricted to the vulnerabilities detectable by ESBMC on this dataset.

All programs shorter than 50 lines were removed from the dataset. However, researchers interested in smaller programs can still find all programs under 50 lines, generated by GPT-3.5-turbo, in the original FormAI-v1 dataset.

8 Conclusions

This research analyzed nine state-of-the-art Large Language Models to assess their likelihood of introducing vulnerabilities during neutral prompt-based code generation, and to

compare their performance. The models included in our analysis were Mistral-7B, Falcon-180B, Falcon2-11B GPT-4o-mini, Llama2-13B, CodeLlama-13B, Gemma-7B, GPT-3.5-turbo, and Gemini-Pro. We employed a zero-shot prompting method to encompass numerous programming scenarios for C code generation. These programs constitute the FormAI-v2 dataset, containing 331 000 independent compilable C programs.

We used the Efficient SMT-based Bounded Model Checker (ESBMC), a state-of-the-art formal verification tool, to identify vulnerabilities. Each program was given a verification period of 500 seconds with the unwinding parameter set to infinite, uncovering a total of 765 366 vulnerabilities. Overall 62.07% of the codes were vulnerable. Detailed labeling of each sample—including filename, type of vulnerability, function name, error type, and source code—is documented in a .json file, as detailed in Appendix Fig. 5, to facilitate the dataset's use in machine learning applications.

Additionally, the FormAI-v2 dataset proved instrumental for fuzzing various applications and identifying multiple bugs in ESBMC and CBMC. These findings provide clear answers to our research questions:

- **RQ1:** How does the security of LLM-generated code differ across various models?
- **Answer:** CodeLlama-13B, Llama-13B, and GPT-4o-mini perform slightly better, but all examined models notoriously introduce vulnerabilities into the C code they generate at unacceptable rates. Our research revealed that all examined models introduced vulnerabilities in at least 50% of the generated code.

- **RQ2:** What are the most typical vulnerabilities introduced by different LLMs during code generation (focusing on C)?
- **Answer:** Dereference failures and buffer overflow issues are the most prevalent vulnerabilities across all models, ranking arithmetic overflow as the third most common type. No model is completely free from any of the examined vulnerabilities; the variations lie in the frequency of occurrence.

While the literature reveals significant variations in these models' ability to solve tasks, this is not mirrored in their susceptibility to produce vulnerabilities in source code. Our findings conclusively show that despite differences among the examined models in terms of generating code, they all consistently introduce severe vulnerabilities when prompted with simple coding tasks. Our study indicates that despite the impressive capabilities of Large Language Models in code generation, employing their output in production requires detailed risk assessment. Relying on these models without expert oversight in a production context is inadvisable.

Appendix

JSON Labels for a GPT-3.5-turbo Generated Sample

```
{
  "category": "VULNERABLE",
  "file_name": "gpt35-58832.c",
  "verification_finished": "yes",
  "vulnerable_line": 42,
  "column": 9,
  "function": "sanitize_url",
  "violated_property": "file gpt35-58832.c line 42 column 9 function
    sanitize_url",
  "stack_trace": "c:@F@sanitize_url at file gpt35-58832.c line 15
    column 5 function main
    c:@F@main
    array bounds violated: array 'temp' lower bound
    (signed long int)(return_value_strlen3 - 1) >= 0",
  "error_type": "array bounds violated: lower bound",
  "code_snippet": "temp[j] = '\\0'; // null-terminate the temporary
    string
    // Remove any trailing slash at the end of the URL
    if (temp[strlen(temp) - 1] == '/')
    {
      temp[strlen(temp) - 1] = '\\0';
    }
    // Convert the URL to lowercase
    for (i = 0; i < strlen(temp); i++)
    {",
  "source_code": "code placeholder",
  "num_lines": 53,
  "cyclomatic_complexity": 3.0
}
```

Fig. 5 Example from the JSON file - FormAI-v2 dataset

Acknowledgements We extend our sincere thanks to the anonymous reviewers for their valuable feedback, which has significantly improved the quality of this paper. This research is supported by the Technology Innovation Institute (TII), Abu Dhabi. Additionally, partial support is provided by the EPSRC grant EP/T026995/1, titled “EnnCore: End-to-End Conceptual Guarding of Neural Architectures” under the Security for All in an AI-enabled Society initiative. This work is also partially supported by the TKP2021-NVA Funding Scheme under Project TKP2021-NVA-29. The University of Oslo was supported by the Research Council of Norway Project No. 312122 “Raksha: 5G Security for Critical Communications”.

Data Availability Statements This study generated and examined a total of 331 000 C samples. The findings and all the generated C samples are available for access and download from the project’s website at <https://github.com/FormAI-Dataset>.

Declarations

Conflicts of interest The authors have no competing interests to declare that are relevant to the content of this article.

References

- Aho AV, Lam MS, Sethi R, Ullman JD (2006) Compilers: Principles, Techniques, And Tools, 2nd edn. Addison-Wesley Longman Publishing Co., Inc, Boston, MA
- Almazrouei E, Alobeidli H, Alshamsi A, Cappelli A, Cojocaru R, Debbah M, Goffinet É, Hesslow D, Launay J, Malartic Q et al (2023) The falcon series of open language models. arXiv preprint [arXiv:2311.16867](https://arxiv.org/abs/2311.16867)

- Alshmrany KM, Aldughaim M, Bhayat A, Cordeiro LC (2021) Fusebmc: An energy-efficient test generator for finding security vulnerabilities in C programs. In: Loulergue F, Wotawa F (eds) Tests and Proofs - 15th International Conference, TAP 2021, Held as Part of STAF 2021, Virtual Event, June 21–22, 2021, Proceedings. Lecture Notes in Computer Science, vol 12740, pp 85–105. Springer
- Anwar U, Saparov A, Rando J, Paleka D, Turpin M, Hase P, Lubana ES, Jenner E, Casper S, Sourburt O et al (2024) Foundational challenges in assuring alignment and safety of large language models. arXiv preprint [arXiv:2404.09932](https://arxiv.org/abs/2404.09932)
- Austin J, Odena A, Nye M, Bosma M, Michalewski H, Dohan D, Jiang E, Cai C, Terry M, Le Q et al (2021) Program synthesis with large language models
- Beyer D (2023) Competition on software verification and witness validation: Sv-comp 2023. In: Sankaranarayanan S, Sharygina N (eds) Tools and Algorithms for the Construction and Analysis of Systems. Springer, Cham, pp 495–522
- Black PE (2018) A Software Assurance Reference Dataset: Thousands of Programs With Known Bugs. Journal of Research of the National Institute of Standards and Technology. 123:1–3. <https://doi.org/10.6028/jres.123.005>. Accessed 27 Jun 2023
- Braberman VA, Bonomo-Braberman F, Charalambous Y, Colonna JG, Cordeiro LC, Freitas R (2024) Tasks People Prompt: A Taxonomy of LLM Downstream Tasks in Software Verification and Falsification Approaches
- Bui NDQ, Le H, Wang Y, Li J, Gotmare AD, Hoi SCH (2023) CodeTF: One-stop Transformer Library for State-of-the-art Code LLM. [arXiv. arxiv:2306.00029](https://arxiv.org/abs/2306.00029). Accessed 22 Jun 2023
- Cao J, Li M, Wen M, Cheung S-c (2023) A study on prompt design, advantages and limitations of chatgpt for deep learning program repair. arXiv preprint [arXiv:2304.08191](https://arxiv.org/abs/2304.08191)
- Chakraborty S, Krishna R, Ding Y, Ray B (2022) Deep Learning Based Vulnerability Detection: Are We There Yet? IEEE Trans Software Eng 48(9):3280–3296. <https://doi.org/10.1109/TSE.2021.3087402>
- Chan A, Kharkar A, Moghaddam RZ, Mohylevskyy Y, Helyar A, Kamal E, Elkamhawy M, Sundaresan N (2023) Transformer-based vulnerability detection in code at edittime: Zero-shot, few-shot, or fine-tuning? arXiv preprint [arXiv:2306.01754](https://arxiv.org/abs/2306.01754)
- Charalambous Y, Tihanyi N, Jain R, Sun Y, Ferrag MA, Cordeiro LC (2023) A New Era in Software Security: Towards Self-Healing Software via Large Language Models and Formal Verification. arXiv . <https://doi.org/10.48550/arXiv.2305.14752>. Accessed 31 May 2023
- Chavez MR, Butler TS, Rekawek P, Heo H, Kinzler WL (2023) Chat Generative Pre-trained Transformer: why we should embrace this technology. Am J Obstet Gynecol 228(6):706–711. <https://doi.org/10.1016/j.jog.2023.03.010>. Accessed 22 Jun 2023
- Chen Y, Ding Z, Alowain L, Chen X, Wagner D (2023) DiverseVul: A New Vulnerable Source Code Dataset for Deep Learning Based Vulnerability Detection. In: Proceedings of the 26th International Symposium on Research in Attacks, Intrusions and Defenses. RAID '23, pp 654–668. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3607199.3607242>
- Chen M, Tworek J, Jun H, Yuan Q, Oliveira Pinto HP, Kaplan J, Edwards H, Burda Y, Joseph N, Brockman G, Ray A, Puri R, Krueger G, Petrov M, Khlaaf H, Sastry G, Mishkin P, Chan B, Gray S, Ryder N, Pavlov M, Power A, Kaiser L, Bavarian M, Winter C, Tillet P, Such FP, Cummings D, Plappert M, Chantzis F, Barnes E, Herbert-Voss A, Guss WH, Nichol A, Paino A, Tezak N, Tang J, Babuschkin I, Balaji S, Jain S, Saunders W, Hesse C, Carr AN, Leike J, Achiam J, Misra V, Morikawa E, Radford A, Knight M, Brundage M, Murati M, Mayer K, Welinder P, McGrew B, Amodei D, McCandlish S, Sutskever I, Zaremba W (2021) Evaluating large language models trained on code. [arXiv:2107.03374](https://arxiv.org/abs/2107.03374). [cs.LG]
- Cordeiro LC, Kroening D, Schrammel P (2019) J BMC: bounded model checking for java bytecode - (competition contribution). In: Tools and Algorithms for the Construction and Analysis of Systems (TACAS). LNCS, vol 11429, pp 219–223. Springer
- Cordeiro L, Fischer B, Marques-Silva J (2012) SMT-Based Bounded Model Checking for Embedded ANSI-C Software. IEEE Trans Software Eng 38(4):957–974. <https://doi.org/10.1109/TSE.2011.59>
- Cordeiro LC, Lima Filho EB, Bessa IV (2020) Survey on automated symbolic verification and its application for synthesising cyber-physical systems. IET Cyber-Phys Syst Theory Appl 5(1):1–24. <https://doi.org/10.1049/IET-CPS.2018.5006>
- Cordy JR, Roy CK (2011) The nicad clone detector. 2011 IEEE 19th International Conference on Program Comprehension 219–220
- Deligiannis P, Lal A, Mehrotra N, Rastogi A (2023) Fixing rust compilation errors using llms. arXiv preprint [arXiv:2308.05177](https://arxiv.org/abs/2308.05177)
- D'Silva V, Kroening D, Weissenbacher G (2008) A Survey of Automated Techniques for Formal Software Verification. IEEE Trans Comput Aided Des Integr Circuits Syst 27(7):1165–1178. <https://doi.org/10.1109/TCAD.2008.923410>

- Fan Z, Gao X, Mirchev M, Roychoudhury A, Tan SH (2023) Automated repair of programs from large language models. In: 2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE), pp 1469–1481. IEEE
- Fan J, Li Y, Wang S, Nguyen TN (2020) A C/C++ Code Vulnerability Dataset with Code Changes and CVE Summaries. In: Proceedings of the 17th International Conference on Mining Software Repositories. MSR '20, pp 508–512. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3379597.3387501>. Accessed 27 Jun 2023
- Gadelha MR, Monteiro FR, Morse J, Cordeiro LC, Fischer B, Nicole DA (2018) ESBMC 5.0: an industrial-strength c model checker. In: Proceedings of the 33rd ACM/IEEE International Conference on Automated Software Engineering, pp 888–891. ACM, Montpellier, France
- Gadelha MR, Monteiro FR, Morse J, Cordeiro LC, Fischer B, Nicole DA (2018) ESBMC 5.0: an industrial-strength c model checker. In: Proceedings of the 33rd ACM/IEEE International Conference on Automated Software Engineering. ASE '18, pp 888–891. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3238147.3240481>
- Gadelha MYR, Monteiro FR, Cordeiro LC, Nicole DA (2019) ESBMC v6.0: Verifying C programs using k-induction and invariant inference - (competition contribution). In: Beyer D, Huisman M, Kordon F, Steffen B (eds) Tools and Algorithms for the Construction and Analysis of Systems (TACAS). LNCS, vol 11429, pp 209–213. Springer
- Gadelha MYR, Steffinlongo E, Cordeiro LC, Fischer B, Nicole DA (2019) Smt-based refutation of spurious bug reports in the clang static analyzer. In: Atlee JM, Bultan T, Whittle J (eds) Proceedings of the 41st International Conference on Software Engineering, pp 11–14. IEEE / ACM, Montreal, QC, Canada. <https://doi.org/10.1109/ICSE-Companion.2019.00026>
- Gadelha MYR, Ismail HI, Cordeiro LC (2017) Handling loops in bounded model checking of C programs via k-induction. Int J Softw Tools Technol Transf 19(1):97–114. <https://doi.org/10.1007/s10009-015-0407-9>
- Gao S, Mao W, Gao C, Li L, Hu X, Xia X, Lyu MR (2024) Learning in the wild: Towards leveraging unlabeled data for effectively tuning pre-trained code models. In: Proceedings of the IEEE/ACM 46th International Conference on Software Engineering, pp 1–13
- Gao Z, Wang H, Zhou Y, Zhu W, Zhang C (2023) How far have we gone in vulnerability detection using large language models. arXiv preprint [arXiv:2311.12420](https://arxiv.org/abs/2311.12420)
- Grishina A, Hort M, Moonen L (2023) The earlybird catches the bug: On exploiting early layers of encoder models for more efficient code classification. In: Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering, pp 895–907
- Guo D, Zhu Q, Yang D, Xie Z, Dong K, Zhang W, Chen G, Bi X, Wu Y, Li Y et al (2024) Deepseek-coder: When the large language model meets programming—the rise of code intelligence. arXiv preprint [arXiv:2401.14196](https://arxiv.org/abs/2401.14196)
- Hao Y, Chen W, Zhou Z, Cui W (2023) E&v: Prompting large language models to perform static analysis by pseudo-code execution and verification. arXiv preprint [arXiv:2312.08477](https://arxiv.org/abs/2312.08477)
- Honarvar S, Wilk M, Donaldson A (2023) Turbulence: Systematically and automatically testing instruction-tuned large language models for code. arXiv preprint [arXiv:2312.14856](https://arxiv.org/abs/2312.14856)
- Hou X, Zhao Y, Liu Y, Yang Z, Wang K, Li L, Luo X, Lo D, Grundy J, Wang H (2023) Large language models for software engineering: A systematic literature review. ACM Trans Softw Eng Method
- Huang D, Bu Q, Zhang JM, Luck M, Cui H (2023) Agentcoder: Multi-agent-based code generation with iterative testing and optimisation. arXiv preprint [arXiv:2312.13010](https://arxiv.org/abs/2312.13010)
- Huang Q, Zhu J, Xing Z, Jin H, Wang C, Xu X (2023) A chain of ai-based solutions for resolving fqns and fixing syntax errors in partial code. arXiv preprint [arXiv:2306.11981](https://arxiv.org/abs/2306.11981)
- Imani S, Du L, Shrivastava H (2023) Mathprompter: Mathematical reasoning using large language models. <https://doi.org/10.48550/arXiv.2303.05398>
- Islam NT, Najafirad P (2024) Code security vulnerability repair using reinforcement learning with large language models. arXiv preprint [arXiv:2401.07031](https://arxiv.org/abs/2401.07031)
- Jain R, Gervasoni N, Ndhlovu M, Rawat S (2023) A code centric evaluation of c/c++ vulnerability datasets for deep learning based vulnerability detection techniques. In: Proceedings of the 16th Innovations in Software Engineering Conference, pp 1–10. ACM, Prayagraj, India
- Jain N, Vaidyanath S, Iyer A, Natarajan N, Parthasarathy S, Rajamani S, Sharma R (2022) Jigsaw: Large language models meet program synthesis. In: Proceedings of the 44th International Conference on Software Engineering, pp 1219–1231
- Jin M, Shahriar S, Tufano M, Shi X, Lu S, Sundaresan N, Svyatkovskiy A (2023) Inferfix: End-to-end program repair with llms. In: Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering, pp 1646–1656

- Jr FEB, Black PE (2012) The Juliet 1.1 C/C++ and Java Test Suite. NIST. 45(10):88–90. Last Modified: 2021-10-12T11:10:04:00 Publisher: Frederick E. Boland Jr., Paul E. Black. Accessed 2023-05-28
- Khare A, Dutta S, Li Z, Solko-Breslin A, Alur R, Naik M (2023) Understanding the effectiveness of large language models in detecting security vulnerabilities. arXiv preprint [arXiv:2311.16169](https://arxiv.org/abs/2311.16169)
- Khoury R, Avila AR, Brunelle J, Camara BM (2023) How secure is code generated by chatgpt? In: 2023 IEEE International Conference on Systems, Man, and Cybernetics (SMC), pp 2445–2451. <https://doi.org/10.1109/SMCS3992.2023.10394237>
- Kim L, Russell R (2018) Draper VDISC Dataset - Vulnerability Detection in Source Code. Publisher: OSF. <https://osf.io/d45bw/> Accessed 27 Jun 2023
- Kirova VD, Ku CS, Laracy JR, Marlowe TJ (2024) Software engineering education must adapt and evolve for an llm environment. In: Proceedings of the 55th ACM Technical Symposium on Computer Science Education V. 1. SIGCSE 2024, pp 666–672. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3626252.3630927>
- Kroening D, Tautschnig M (2014) Cbmc-c bounded model checker: (competition contribution). In: Tools and Algorithms for the Construction and Analysis of Systems: TACAS 2014, pp 389–391. Springer, Grenoble, France
- Lajkó M, Csuvik V, Vidács L (2022) Towards javascript program repair with generative pre-trained transformer (gpt-2). In: Proceedings of the Third International Workshop on Automated Program Repair, pp 61–68. IEEE, ???
- Li T-O, Zong W, Wang Y, Tian H, Wang Y, Cheung S-C (2023) Finding Failure-Inducing Test Cases with ChatGPT
- Liang X, Song S, Zheng Z, Wang H, Yu Q, Li X, Li R-H, Xiong F, Li Z (2024) Internal consistency and self-feedback in large language models: A survey. arXiv preprint [arXiv:2407.14507](https://arxiv.org/abs/2407.14507)
- Lin F, Kim DJ et al (2024) When llm-based code generation meets the software development process. arXiv preprint [arXiv:2403.15852](https://arxiv.org/abs/2403.15852)
- Lu S, Guo D, Ren S, Huang J, Svyatkovskiy A, Blanco A, Clement C, Drain D, Jiang D, Tang D et al (2021) Codexglue: A machine learning benchmark dataset for code understanding and generation. arXiv preprint [arXiv:2102.04664](https://arxiv.org/abs/2102.04664)
- Ma W, Liu S, Wang W, Hu Q, Liu Y, Zhang C, Nie L, Liu Y (2023) The Scope of ChatGPT in Software Engineering: A Thorough Investigation. arXiv. <https://doi.org/10.48550/arXiv.2305.12138>. Accessed 10 Jun 2023
- Marjamäki D (2024) Cppcheck: A Tool for Static Analysis of C/C++ Code. <https://cppcheck.sourceforge.io/>. [Online], Available at: <https://cppcheck.sourceforge.io/>. Accessed 12 Sept 2024
- McCabe TJ (1976) A complexity measure. IEEE Trans Softw Eng SE-2(4):308–320. <https://doi.org/10.1109/TSE.1976.233837>
- Menezes RS, Aldughaim M, Farias B, Li X, Manino E, Shmarov F, Song K, Brauße F, Gadelha MR, Tihanyi N, Korovin K, Cordeiro LC (2024) ESBMC v7.4: Harnessing the power of intervals - (competition contribution). In: Tools and Algorithms for the Construction and Analysis of Systems (TACAS). LNCS, vol 14572, pp 376–380. Springer
- Menezes R, Moura D, Cavalcante H, Freitas R, Cordeiro LC (2022) Esbmc-jimple: verifying kotlin programs via jimple intermediate representation. In: Ryu S, Smaragdakis Y (eds) ISSTA '22: 31st ACM SIGSOFT International Symposium on Software Testing and Analysis, Virtual Event, South Korea, July 18 - 22, 2022, pp 777–780. ACM
- Mikejo5000 (2024) Code metrics - Cyclomatic complexity - Visual Studio (Windows). <https://learn.microsoft.com/en-us/visualstudio/code-quality/code-metrics-cyclomatic-complexity?view=vs-2022>. Accessed 18 Apr 2024
- Mirzadeh I, Alizadeh K, Shahrokhi H, Tuzel O, Bengio S, Farajtabar M (2024) Gsm-symbolic: Understanding the limitations of mathematical reasoning in large language models. arXiv preprint [arXiv:2410.05229](https://arxiv.org/abs/2410.05229)
- Mohajer MM, Aleithan R, Harzevili NS, Wei M, Belle AB, Pham HV, Wang S (2023) Skipanalyzer: An embodied agent for code analysis with large language models. arXiv preprint [arXiv:2310.18532](https://arxiv.org/abs/2310.18532)
- Morse J, Cordeiro LC, Nicole DA, Fischer B (2011) Context-bounded model checking of LTL properties for ANSI-C software. In: Barthe G, Pardo A, Schneider G (eds) Software Engineering and Formal Methods - 9th International Conference, SEFM 2011, Montevideo, Uruguay, November 14-18, 2011. Proceedings. Lecture Notes in Computer Science, vol 7041, pp 302–317. Springer
- Muennighoff N, Liu Q, Zebaze A, Zheng Q, Hui B, Zhuo TY, Singh S, Tang X, Von Werra L, Longpre S (2023) Octopack: Instruction tuning code large language models. arXiv preprint [arXiv:2308.07124](https://arxiv.org/abs/2308.07124)
- Nehorai N (2024) Analyzing Common Vulnerabilities Introduced by Code-Generative AI | HackerNoon. <https://hackernoon.com/analyzing-common-vulnerabilities-introduced-by-code-generative-ai>. Accessed 28 Feb 2024

- Nguyen V, Yuan X, Wu T, Nepal S, Grobler M, Rudolph C (2024) Deep learning-based out-of-distribution source code data identification: How far we have gone? arXiv preprint [arXiv:2404.05964](https://arxiv.org/abs/2404.05964)
- Noever D (2023) Can large language models find and fix vulnerable software? arXiv preprint [arXiv:2308.10345](https://arxiv.org/abs/2308.10345)
- OpenAI (2023) GPT-4 Technical Report. [arXiv. arxiv:2303.08774](https://arxiv.org/abs/2303.08774). Accessed 29 May 2023
- Paul R, Mohib Hossain M, Hasan M, Iqbal A (2023) Automated program repair based on code review: How do pre-trained transformer models perform? arXiv e-prints, 2304
- Pearce H, Ahmad B, Tan B, Dolan-Gavitt B, Karri R (2022) Asleep at the keyboard? assessing the security of github copilot's code contributions. In: 2022 IEEE Symposium on Security and Privacy (SP), pp 754–768. IEEE, ???
- Pearce H, Tan B, Ahmad B, Karri R, Dolan-Gavitt B (2023) Examining zero-shot vulnerability repair with large language models. In: 2023 IEEE Symposium on Security and Privacy (SP), pp 2339–2356. IEEE, ???
- Peng Y, Gao S, Gao C, Huo Y, Lyu M (2024) Domain knowledge matters: Improving prompts with fix templates for repairing python type errors. In: Proceedings of the IEEE/ACM 46th International Conference on Software Engineering, ICSE '24. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3597503.3608132>
- Perry N, Srivastava M, Kumar D, Boneh D (2023) Do users write more insecure code with ai assistants? In: Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security, CCS '23, pp 2785–2799. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3576915.3623157>
- Quan VLA, Phat CT, Van Nguyen K, Duy PT, Pham V-H (2023) Xgv-bert: Leveraging contextualized language model and graph neural network for efficient software vulnerability detection. arXiv preprint [arXiv:2309.14677](https://arxiv.org/abs/2309.14677)
- Ross SI, Martinez F, Houde S, Muller M, Weisz JD (2023) The Programmer's Assistant: Conversational Interaction with a Large Language Model for Software Development. In: Proceedings of the 28th International Conference on Intelligent User Interfaces, IUI '23, pp. 491–514. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3581641.3584037>. Accessed 22 Jun 2023
- Roziere B, Gehring J, Gloeckle F, Sootla S, Gat I, Tan XE, Adi Y, Liu J, Remez T, Rapin J et al (2023) Code llama: Open foundation models for code. arXiv preprint [arXiv:2308.12950](https://arxiv.org/abs/2308.12950)
- Russell RL, Kim LY, Hamilton LH, Lazovich T, Harer JA, Ozdemir O, Ellingwood PM, McConley MW (2018) Automated Vulnerability Detection in Source Code Using Deep Representation Learning. In: 2018 17th IEEE International Conference on Machine Learning and Applications (ICMLA), pp. 757–762. IEEE, Orlando, FL, USA. <https://doi.org/10.1109/ICMLA.2018.00120>. <https://api.semanticscholar.org/CorpusID:49670513>
- Sadowski C, Yi J (2014) How developers use data race detection tools. In: Proceedings of the 5th Workshop on Evaluation and Usability of Programming Languages and Tools, pp 43–51. ACM, Portland, USA
- Sandoval G, Pearce H, Nys T, Karri R, Garg S, Dolan-Gavitt B (2023) Lost at c: A user study on the security implications of large language model code assistants. In: 32nd USENIX Security Symposium (USENIX Security 23), pp 2205–2222. USENIX Association
- Shestov A, Cheshkov A, Levichev R, Mussabayev R, Zadorozhny P, Maslov E, Vadim C, Bulychev E (2024) Finetuning large language models for vulnerability detection. arXiv preprint [arXiv:2401.17010](https://arxiv.org/abs/2401.17010)
- Shumailov I, Shumaylov Z, Zhao Y, Gal Y, Papernot N, Anderson R (2023) The Curse of Recursion: Training on Generated Data Makes Models Forget. [arXiv. arxiv:2305.17493](https://arxiv.org/abs/2305.17493). Accessed 2023-06-27
- Steenhoek B, Gao H, Le W (2024) Dataflow analysis-inspired deep learning for efficient vulnerability detection. In: Proceedings of the IEEE/ACM 46th International Conference on Software Engineering, ICSE '24. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3597503.3623345>
- Sun T, Allix K, Kim K, Zhou X, Kim D, Lo D, Bissyandé TF, Klein J (2023) Dexbert: Effective, task-agnostic and fine-grained representation learning of android bytecode. IEEE Trans Software Eng 49(10):4691–4706. <https://doi.org/10.1109/TSE.2023.3310874>
- Sun Y, Wu D, Xue Y, Liu H, Ma W, Zhang L, Shi M, Liu Y (2024) Llm4vuln: A unified evaluation framework for decoupling and enhancing llms' vulnerability reasoning. arXiv preprint [arXiv:2401.16185](https://arxiv.org/abs/2401.16185)
- Tang W, Tang M, Ban M, Zhao Z, Feng M (2023) Csgvd: A deep learning approach combining sequence and graph embedding for source code vulnerability detection. J Syst Softw 199(C). <https://doi.org/10.1016/j.jss.2023.111623>
- Team G, Anil R, Borgeaud S, Wu Y, Alayrac J-B, Yu J, Soricut R, Schalkwyk J, Dai AM, Hauth A et al (2023) Gemini: a family of highly capable multimodal models. arXiv preprint [arXiv:2312.11805](https://arxiv.org/abs/2312.11805)
- Thapa C, Jang SI, Ahmed ME, Camtepe S, Pieprzyk J, Nepal S (2022) Transformer-based language models for software vulnerability detection. In: Proceedings of the 38th Annual Computer Security Applications Conference, ACSAC '22, pp 481–496. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3564625.3567985>

- Tian H, Liu K, Kaboré AK, Koyuncu A, Li L, Klein J, Bisseyandé TF (2021) Evaluating representation learning of code changes for predicting patch correctness in program repair. In: Proceedings of the 35th IEEE/ACM International Conference on Automated Software Engineering. ASE '20, pp 981–992. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3324884.3416532>
- Tian H, Liu K, Li Y, Kaboré AK, Koyuncu A, Habib A, Li L, Wen J, Klein J, Bisseyandé TF (2023) The best of both worlds: Combining learned embeddings with engineered features for accurate prediction of correct patches. *ACM Trans Softw Eng Methodol* 32(4). <https://doi.org/10.1145/3576039>
- Tihanyi N, Bisztray T, Dubniczky RA, Toth R, Borsos B, Cherif B, Ferrag MA, Muzsai L, Jain R, Marinelli R et al (2024) Dynamic intelligence assessment: Benchmarking llms on the road to agi with a focus on model confidence. *arXiv preprint arXiv:2410.15490*
- Tihanyi N, Bisztray T, Jain R, Amine Ferrag M, Cordeiro LC, Mavroeidis V (2023) FormAI Dataset: A Large Collection of AI-Generated C Programs and Their Vulnerability Classifications. *IEEE Dataport*. <https://doi.org/10.21227/vp9n-wv96>
- Tihanyi N, Bisztray T, Jain R, Ferrag MA, Cordeiro LC, Mavroeidis V (2023) The formai dataset: Generative ai in software security through the lens of formal verification. In: Proceedings of the 19th International Conference on Predictive Models and Data Analytics in Software Engineering. PROMISE 2023, pp 33–43. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3617555.3617874>
- Tóth R, Bisztray T, Erdődi L (2024) Llms in web development: Evaluating llm-generated php code unveiling vulnerabilities and limitations. *Computer Safety, Reliability, and Security. SAFECOMP 2024 Workshops*. Springer, Cham, pp 425–437
- Wallace DR, Fujii RU (1989) Software verification and validation: an overview. *IEEE Softw* 6(3):10–17. <https://doi.org/10.1109/52.28119>. Accessed 22 Jun 2023
- Wang J, Huang Y, Chen C, Liu Z, Wang S, Wang Q (2024) Software testing with large language models: Survey, landscape, and vision. *IEEE Trans Software Eng*
- Wang H, Liu Z, Wang S, Cui G, Ding N, Liu Z, Yu G (2023) Intervenor: Prompt the coding ability of large language models with the interactive chain of repairing. *arXiv preprint arXiv:2311.09868*
- Wang S, Long Z, Fan Z, Wei Z, Huang X (2024) Benchmark self-evolving: A multi-agent framework for dynamic llm evaluation. *arXiv preprint arXiv:2402.11443*
- Wang W, Wang Y, Joty S, Hoi SCH (2023) Rap-gen: Retrieval-augmented patch generation with codet5 for automatic program repair. In: Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering. ESEC/FSE 2023, pp 146–158. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3611643.3616256>
- Wei J, Wang X, Schuurmans D, Bosma M, Xia F, Chi E, Le QV, Zhou D (2022) Chain-of-thought prompting elicits reasoning in large language models. *Adv Neural Inf Process Syst* 35:24824–24837
- Wei Y, Xia CS, Zhang L (2023) Copiloting the copilots: Fusing large language models with completion engines for automated program repair. In: Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering. ESEC/FSE 2023, pp 172–184. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3611643.3616271>
- White J, Fu Q, Hays S, Sandborn M, Olea C, Gilbert H, Elnashar A, Spencer-Smith J, Schmidt DC (2023) A Prompt Pattern Catalog to Enhance Prompt Engineering with ChatGPT. *arXiv*. <https://doi.org/10.48550/arXiv.2302.11382>. Accessed 24 Jun 2023
- White M, Tufano M, Vendome C, Poshvanyk D (2016) Deep learning code fragments for code clone detection. In: Proceedings of the 31st IEEE/ACM International Conference on Automated Software Engineering, pp 87–98. Association for Computing Machinery, New York, USA
- Widjojo P, Treude C (2023) Addressing compiler errors: Stack overflow or large language models? *arXiv preprint arXiv:2307.10793*
- Wu Y, Jiang N, Pham HV, Lutellier T, Davis J, Tan L, Babkin P, Shah S (2023) How effective are neural networks for fixing security vulnerabilities. In: Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis, pp 1282–1294
- Wu Y, Li Z, Zhang JM, Papadakis M, Harman M, Liu Y (2023) Large language models in fault localisation. *arXiv preprint arXiv:2308.15276*
- Xia CS, Wei Y, Zhang L (2022) Practical program repair in the era of large pre-trained language models. *arXiv preprint arXiv:2210.14179*
- Xia CS, Zhang L (2023) Keep the conversation going: Fixing 162 out of 337 bugs for \$0.42 each using chatgpt. *arXiv preprint arXiv:2304.00385*
- Xu FF, Alon U, Neubig G, Hellendoorn VJ (2022) A systematic evaluation of large language models of code. In: Proceedings of the 6th ACM SIGPLAN International Symposium on Machine Programming, pp 1–10
- Yang AZ, Le Goues C, Martins R, Hellendoorn V (2024) Large language models for test-free fault localization. In: Proceedings of the 46th IEEE/ACM International Conference on Software Engineering, pp 1–12

- Yao S, Yu D, Zhao J, Shafran I, Griffiths T, Cao Y, Narasimhan K (2024) Tree of thoughts: Deliberate problem solving with large language models. In: *Advances in Neural Information Processing Systems*, vol 36
- Zhang Q, Fang C, Sun W, Liu Y, He T, Hao X, Chen Z (2024) Appt: Boosting automated patch correctness prediction via fine-tuning pre-trained models. *IEEE Trans Software Eng* 50(3):474–494. <https://doi.org/10.1109/TSE.2024.3354969>
- Zhang Q, Fang C, Zhang T, Yu B, Sun W, Chen Z (2023) Gamma: Revisiting template-based automated program repair via mask prediction. In: *Proceedings of the 38th IEEE/ACM International Conference on Automated Software Engineering (ASE)*, pp 535–547. IEEE
- Zhang Y, Jin Z, Xing Y, Li G (2023) Steam: simulating the interactive behavior of programmers for automatic bug fixing. arXiv preprint [arXiv:2308.14460](https://arxiv.org/abs/2308.14460)
- Zhang Y, Li G, Jin Z, Xing Y (2023) Neural program repair with program dependence analysis and effective filter mechanism. arXiv preprint [arXiv:2305.09315](https://arxiv.org/abs/2305.09315)
- Zhang C, Liu H, Zeng J, Yang K, Li Y, Li H (2023) Prompt-enhanced software vulnerability detection using chatgpt. arXiv preprint [arXiv:2308.12697](https://arxiv.org/abs/2308.12697)
- Zhao J, Huang J (2018) Deepsim: deep learning code functional similarity. In: *Proceedings of the 2018 26th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, pp 141–151. ACM, Lake Buena Vista, USA
- Zhou Y, Liu S, Siow J, Du X, Liu Y (2019) Devign: Effective Vulnerability Identification by Learning Comprehensive Program Semantics via Graph Neural Networks, pp 10197–10207. Curran Associates Inc., Red Hook, NY, USA

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Springer Nature or its licensor (e.g. a society or other partner) holds exclusive rights to this article under a publishing agreement with the author(s) or other rightsholder(s); author self-archiving of the accepted manuscript version of this article is solely governed by the terms of such publishing agreement and applicable law.



Norbert Tihanyi (Member, IEEE) holds a B.Sc. in Security Engineering, an M.Sc. in Safety Engineering, and an additional M.Sc. with honors in IT Engineering. He earned a Ph.D. in Information Science and Technology from Eötvös Loránd University in Budapest, Hungary, in 2020. Currently, he is a Public Body Member of the Hungarian Academy of Sciences and serves as a Lead Researcher at the Technology Innovation Institute (TII) in Abu Dhabi, United Arab Emirates. His research interests include cryptanalysis, embedded device security, and cryptography-related prime number theory.



Tamas Bisztray received the B.Sc. degree in mathematics from Eötvös Loránd University, Hungary, an M.Sc. degree in computer science from the University of Trento, Italy, and a Ph.D. degree from the University of Oslo, Norway. He is currently a Researcher at the University of Oslo. His research interests include digital privacy, applications of AI in cybersecurity, and 5G security.



Mohamed Amine Ferrag earned his Bachelor's, Master's, Ph.D., and Habilitation degrees in Computer Science from Badji Mokhtar-Annaba University in Annaba, Algeria, completing his studies in 2008, 2010, 2014, and 2019, respectively. He has served as an Associate Professor in the Department of Computer Science at Guelma University, Algeria, from 2014 until now. From 2022 to 2024, he worked as Lead Researcher with the Technology Innovation Institute (TII) in Abu Dhabi, United Arab Emirates. Concurrently, from 2019 to 2022, he was a Senior Researcher at the NAU-Lincoln Joint Research Center of Intelligent Engineering, based at Nanjing Agricultural University in China. Dr. Ferrag's research primarily focuses on various topics within the cybersecurity domain, including wireless network security, network coding security, applied cryptography, blockchain technology, generative AI, software security, and the application of AI in cybersecurity. His scholarly output is impressive, with over 160 research papers published in international journals and conference proceedings.

His work has garnered significant recognition, evidenced by his citation count of over 10320, an h-index of 42, and an i10-index of 91. He has led numerous projects in research and development, fostering collaborative ties with academic institutions in the UK, Australia, USA, Canada, and China. His contributions to the field include the creation of four cybersecurity datasets: the Edge-IIoT dataset, FormAI dataset, CyberMetric dataset, and DIA dataset. These datasets have become essential resources for AI researchers worldwide. Dr. Ferrag's academic contributions have been recognized with the 2021 IEEE TEM Best Paper Award and the 2022 Scopus Algeria Award, among many best paper conference awards. He has consistently been named on Stanford University's list of the world's top 2% of scientists five times from 2020 through 2024. In addition to his research and editorial roles as an associate editor for prestigious journals such as the IEEE Internet of Things Journal and ICT Express (Elsevier), Dr. Ferrag is a Senior Member of the Institute of Electrical and Electronics Engineers (IEEE).



Ridhi Jain is a Senior Security Researcher at the Technology Innovation Institute (TII), UAE. Her research interests include software verification, program analysis, and vulnerability detection. She is also a PhD candidate at the Indraprastha Institute of Information Technology Delhi (IIIT-Delhi), specializing in methods for verifying concurrent software under relaxed memory models.



Lucas C. Cordeiro is a Full Professor in the Department of Computer Science (CS) at the University of Manchester (UoM), where he leads the Systems and Software Security (S3) Research Group. Prof. Cordeiro is also the Business Engagement and Innovation Director in the CS department and the Arm Centre of Excellence Director at UoM. In addition, he is affiliated with the Trusted Digital Systems Cluster at the Centre for Digital Trust and Society, the Formal Methods Group at UoM, and the Post-Graduate Programs in Electrical Engineering (PPGEE) and Informatics (PPGI) at the Federal University of Amazonas, Brazil. He is also a member of the technical advisory board at Axiomise. Before joining the University of Manchester, he worked as a post-doctoral researcher at the University of Oxford and as a research engineer at Diffblue. In addition, Dr. Cordeiro worked for five years as a software engineer at Siemens / BenQ Mobile and CTPIM / NXP semiconductors. His work focuses on software model checking, automated testing, program synthesis,

software security, embedded and cyber-physical systems. He has co-authored more than 150 peer-reviewed publications in the most prestigious venues (e.g., ICSE, CAV, TACAS, FSE, ASE, ISSTA, TSE, TR, TC). He has received various international awards, including the Most Influential Paper at ASE'23, the Distinguished Paper Award at ICSE'11 and ASE'24, and 39 awards from the international competitions on software verification (SV-COMP) and testing (Test-Comp) 2012-2023. He has a proven track record of securing research funding from EPSRC, Intel, Motorola, Samsung, Nokia Institute of Technology, CNPq, FAPEAM, British Council, and Royal Society (career total over USD 13M).